CYPHER GROUP INC. · SIMULATED CASE STUDY

# CGI-SOC-001 — SOC 2 Type II Readiness Assessment · CGI-IAU-001 — Internal Audit Workpapers

## Cypher Group Inc. · Version 1.0 · 25 September 2026

> **CASE STUDY NOTICE.** Cypher Group Inc. is a simulated company. Every organisation, person, system, finding, score, date, cost and figure in this document was created to demonstrate applied GRC methodology. This is a portfolio artifact, not evidence of employment or of a real engagement. AICPA Trust Services Criteria and ISO/IEC 27001 requirement wording are paraphrased; obtain the criteria from the AICPA and the standard from ISO or a national body.

| Field | Value |
|---|---|
| Document IDs | **CGI-SOC-001** (SOC 2 readiness) · **CGI-IAU-001** (internal audit workpapers) |
| Version | 1.0 |
| Status | Draft for approval |
| Assessment and audit date | 25 September 2026 |
| Simulated fieldwork | 21–25 September 2026 |
| Prepared by | O.S — assessor and internal auditor |
| Approving authority | Jerry Gold, Chief Executive Officer |
| Criteria | AICPA **2017 Trust Services Criteria** with the **2022 revised points of focus** — Security (CC1–CC9), Availability (A1), Confidentiality (C1) |
| Audit criteria | ISO/IEC 27001:2022 incl. Amd 1:2024 clauses 4–10; the 88 applicable Annex A controls per CGI-ISO-001; CGI-POL-001 to -005 |
| Inputs consumed | CGI-POL-001 to -005 v1.0 · CGI-TRK-001 · EXC-001 to -003 · CGI-RSK-001 v1.1 (14 risks) · CGI-GAP-001 v1.0 as updated by Project 4 · CGI-TPR-001 / -002 (17 vendors) · CGI-ISO-001 v1.0 draft (93-control SoA) |
| Next review | On completion of the independent internal audit (ISO-12, May 2027) |

> **DECLARED INDEPENDENCE LIMITATION.** The auditor prepared CGI-ISO-001, including the Statement of Applicability tested in **WP-06**. ISO/IEC 27001 clause 9.2.2 c) requires auditors to be selected so as to ensure objectivity and impartiality, and an auditor shall not audit their own work. **CGI-IAU-001 is therefore a dry run.** It delivers the programme, the method and the workpapers that action ISO-12 will use in May 2027. It does not, and cannot, discharge clause 9.2. See finding **OFI-08**.

---

**Headline result.** Thirty-eight Trust Services Criteria apply once Security, Availability and Confidentiality are selected. **8 of 38 have an adequate design. None has operating evidence.** Type I readiness is **53.9%**, Type II readiness is **36.0%**, and **6 of 8 gates fail**, so both are a **NO-GO**. The internal audit raised **37 findings: 9 major nonconformities, 10 minor and 18 opportunities for improvement**, and **36 of 50 evidence requests (72%) could not be answered because the evidence does not exist.** The realistic first SOC 2 Type II report is **November 2028**, after the ISO certificate in November 2027.

---

## Contents

1. The Why — SOC 2 and internal audit in plain English
2. Criteria selection and the TSC-to-SoA crosswalk
3. Draft system description, CUECs and CSOCs
4. SOC 2 readiness gap assessment and go/no-go
5. Internal audit plan, workpapers, findings and audit report
6. PBC evidence request list

7. Roadmap reconciled against ISO-01 to ISO-17 and REC-01 to REC-18
8. One-page executive summary
9. Effect on the CGI-GAP-001 maturity score

- Appendix A — Verification, assumptions and limitations
- Appendix B — Glossary

### Files in this deliverable

| File | What it is |
|---|---|
| `06-soc2-readiness-internal-audit/06-soc2-readiness-and-internal-audit.md` | This document |
| `06-soc2-readiness-internal-audit/06-soc2-readiness-and-internal-audit.pdf` | The same document, formatted for reading or printing |
| `06-soc2-readiness-internal-audit/06-soc2-readiness-and-internal-audit.xlsx` | Working workbook — 17 sheets, 814 live formulas, recalculated to zero errors |
| `06-soc2-readiness-internal-audit/06-soc2-readiness-and-internal-audit.csv` | The full 38-criterion crosswalk, 18 columns; also the Notion import |
| `data/06-tsc-soa-crosswalk.csv` | The crosswalk again, inside `data/` for tooling that expects it there |
| `data/06-criteria-selection.csv` | Which Trust Services categories are in scope and why |
| `data/06-cuec-schedule.csv` | Cypher Group Inc.'s own complementary user entity controls |
| `data/06-csoc-schedule.csv` | Controls relied on from the carved-out subservice organisation |
| `data/06-cuec-mirror-reconciliation.csv` | Our CUECs against the CloudCo CUECs we have not accepted |
| `data/06-readiness-gates.csv` · `data/06-readiness-score.csv` | The gates and the scored result |
| `data/06-framework-overlap.csv` | Where one control satisfies both frameworks and where it does not |
| `data/06-internal-audit-workpapers.csv` | WP-01 to WP-24, 17 columns |
| `data/06-wp06-soa-sample.csv` | The reproducible 15-row SoA sample tested in WP-06 |
| `data/06-findings-register.csv` | 37 findings with owners, responses and dates |
| `data/06-pbc-request-list.csv` | PBC-01 to PBC-50 |
| `data/06-soc2-roadmap.csv` · `data/06-reconciliation-conflicts.csv` · `data/06-maturity-projection.csv` | The plan, the conflicts and the maturity effect |
| `templates/soc2-tsc-crosswalk-template.md` · `.csv` | Blank bracketed crosswalk with the scoring method restated |
| `templates/internal-audit-workpaper-template.md` · `.csv` · `.docx` | Blank bracketed workpaper, sampling rules and rating tests |
| `templates/pbc-request-list-template.md` · `.csv` | Blank bracketed PBC list with the status vocabulary |

## Part 1 — The Why

### 1.1 What SOC 2 is, and what it is not

**SOC** stands for **System and Organization Controls**. The framework belongs to the **AICPA**, the American Institute of Certified Public Accountants. A SOC 2 engagement is performed by an independent **CPA firm** — a firm of licensed Certified Public Accountants — under **SSAE 18**, the Statement on Standards for Attestation Engagements, as an *examination* engagement (AT-C sections 105 and 205).

There are three members of the family. **SOC 1** covers controls relevant to a customer's financial reporting. **SOC 2** covers the Trust Services Criteria. **SOC 3** is a short public summary of a SOC 2 with the test detail removed. Cypher Group Inc. needs **SOC 2**.

**A SOC 2 is a report, not a certificate.** There is no SOC 2 certificate, no accreditation body and no expiry sticker. Nobody is "SOC 2 certified". The output is a document of sixty to a hundred pages containing an opinion, management's own description of the system, and the auditor's tests and results — including every exception found.

It is also not a fixed control list. ISO/IEC 27001 hands you 93 Annex A controls. SOC 2 hands you **criteria**, which are *outcomes*. You write your own controls, and the examiner tests **yours** against the criteria. Two companies can both hold clean SOC 2 reports with entirely different control sets.

## 1.2 Attestation versus certification

| | SOC 2 — attestation | ISO/IEC 27001 — certification |
|---|---|---|
| What is produced | A report with an opinion and the detailed test results | A certificate |
| Who produces it | A CPA firm under AICPA standards | An accredited certification body |
| Who claims first | **Management asserts; the examiner attests to the assertion** | The certification body audits the organisation directly |
| Validity | The stated period only | Three-year cycle with surveillance audits |
| Who may read it | Customers, normally under NDA | Anyone — certificates are public |
| Can parts be left out | Choose which categories to include | Annex A controls may be excluded with justification; clauses never |
| Length | 60–100 pages | One page |

The mechanism worth memorising: **in an attestation, the organisation makes the claim and the examiner agrees or disagrees with it.** That is why the system description in Part 3 is written by Cypher Group Inc. and not by the auditor. If the description claims a control the company does not have, the failure is not in the control — it is that **the description is not fairly presented**, which is the more serious finding of the two.

## 1.3 Type I and Type II

A **Type I** report covers the **design and implementation** of controls **as of a single date**: *"suitably designed and implemented as of 31 March 2028"*. A **Type II** report covers design **and operating effectiveness over a period**: *"1 April 2028 to 30 September 2028"*. A Type I is a photograph. A Type II is a film. The minimum observation period for a Type II is normally three months; six months is the market norm for a first report and twelve months thereafter.

Most enterprise buyers now treat a Type I as a promise rather than evidence. It is worth doing only when it starts the clock on a Type II.

## 1.4 The Trust Services Criteria and the points of focus

The criteria are grouped into **five categories**: **Security**, **Availability**, **Confidentiality**, **Processing Integrity** and **Privacy**. Security is mandatory in every engagement and is also called the **Common Criteria**, because it is common to all five. It runs **CC1 to CC9**:

| Group | Name | What it asks |
|---|---|---|
| **CC1** | Control Environment | Do the people at the top take this seriously? |
| **CC2** | Communication and Information | Does everyone inside and outside know the rules and the commitments? |
| **CC3** | Risk Assessment | Do you know what can go wrong, including fraud? |
| **CC4** | Monitoring Activities | Do you check yourself, and act on what you find? |

| Group | Name | What it asks |
|---|---|---|
| **CC5** | Control Activities | Do you actually have controls, deployed through policy? |
| **CC6** | Logical and Physical Access Controls | Who can get in, and to what? |
| **CC7** | System Operations | Do you spot, judge, handle and recover from incidents? |
| **CC8** | Change Management | Does change go through a gate? |
| **CC9** | Risk Mitigation | Business disruption, and vendors |

CC1 to CC5 are the **COSO** framework — the 2013 internal control framework of the Committee of Sponsoring Organizations of the Treadway Commission — mapped into the criteria. That is why CC1 reads like a governance and HR chapter rather than a security one. Availability adds **A1.1 to A1.3**, Confidentiality adds **C1.1 and C1.2**, Processing Integrity adds **PI1**, Privacy adds **P1 to P8**.

**Points of focus** were revised in 2022. They are suggested characteristics that *illustrate* a criterion. **They are not requirements.** An organisation must meet the criterion; it does not have to tick every point of focus, and an examiner who treats them as a checklist is applying the framework wrongly. Every row of the crosswalk in Part 2 carries a summary of the relevant points of focus so that the judgement behind the score is visible.

## 1.5 The system description, CUECs and CSOCs

A SOC 2 report has four sections: **(1)** the independent service auditor's report, containing the opinion; **(2)** management's assertion; **(3)** management's description of the system; **(4)** the auditor's tests of controls and the results. Two of the four are written by the organisation.

The **system description** sets out the services, the infrastructure, software, people, procedures and data, the boundaries of the system, the principal service commitments and system requirements, the controls, the complementary controls that others must perform, and any significant changes during the period.

A **CUEC** — **complementary user entity control** — is a control the **customer** must perform for the provider's controls to work. *User entities are responsible for removing their own users promptly when staff leave.* A **CSOC** — **complementary subservice organization control** — is a control a **supplier** must perform for the provider's controls to work.

Where a subservice organisation is involved, the description uses either the **carve-out method** (the supplier's controls are excluded from the description and from testing; the supplier is named, what it does is described, and CSOCs are listed) or the **inclusive method** (the supplier's controls are described and tested by the same auditor). Cypher Group Inc. **carves out CloudCo**. The inclusive method requires the supplier's cooperation, and no hyperscale provider offers it to a fifty-person company.

## 1.6 Opinions and exceptions

| Opinion | Meaning |
|---|---|
| **Unqualified** | Clean |
| **Qualified** | Clean *except for* one or more identified matters |
| **Adverse** | The description is materially misstated, or controls broadly failed |
| **Disclaimer** | The auditor could not obtain sufficient evidence to form an opinion |

An **exception** is a single instance in which a control did not operate as described — *"for 2 of 25 leavers sampled, access was revoked outside the four-hour requirement"*. **Exceptions do not automatically qualify the opinion.** The examiner judges severity, and a Type II report carrying a handful of exceptions, each with a management response beside it, is normal and healthy. Writing that response is a core part of the job.

## 1.7 Internal audit under ISO/IEC 27001 clause 9.2

**Clause 9.2.1** requires internal audits at planned intervals to determine whether the ISMS conforms to **the organisation's own requirements** *and* to the standard, and is effectively implemented and maintained. The first half

matters: **an internal audit tests the organisation against its own documents.** If the access policy says four hours and the practice is six, that is a nonconformity even though the standard never mentions four hours.

**Clause 9.2.2** requires an audit **programme**: frequency, methods, responsibilities, planning and reporting; consideration of importance and prior results; defined criteria and scope for each audit; auditor selection that ensures **objectivity and impartiality**; reporting of results to relevant management; and retention of documented evidence.

It is not the certification audit — that is Stage 1 and Stage 2. It is not optional; no clause may be excluded. And it is not a readiness assessment: a readiness assessment gives advice, while an internal audit performs tests against a population and raises findings that management must respond to.

## 1.8 Independence, sampling, design versus operation, and workpapers

**Independence.** Under the AICPA Code of Professional Conduct a CPA firm must be independent in fact and in appearance, and a firm that designs or implements controls may not examine them. ISO's equivalent is clause 9.2.2 c): objectivity and impartiality, which in practice means an auditor does not audit their own work. The limitation declared at the top of this document is that rule applied to this engagement rather than hidden by it.

**Sampling.** The **population** is every occurrence of a control in the period. A **sample** is the subset tested, and a **deviation** or **exception** is a sampled item that failed. GRC work is almost entirely **attribute sampling** — testing a yes-or-no property such as *was it approved* or *was it inside four hours*. Practical sizes: an annual control gives 1, quarterly 2, monthly 2–5, weekly 5–15, daily 20–40, ad hoc 25–60, and **any population below about 25 is tested in full**. The method must be stated and reproducible: random with a recorded seed, systematic, haphazard or judgemental.

Two rules dominate this engagement. First, **where a control operated zero times in the period the population is zero; it cannot be sampled, and the honest record is "no instances occurred" plus a test of design alone**. Second, **the hard part is not the sample but proving the population is complete** — completeness and accuracy of any *information produced by the entity* (IPE). A flawless sample drawn from the wrong universe proves nothing, and WP-17 is this document's demonstration of exactly that failure.

**Design versus operation.** A **test of design** asks whether the control, as described, would meet the criterion if it operated as intended; evidence is the document, a walkthrough, an observation or a configuration. A **test of operating effectiveness** asks whether it actually operated that way throughout the period; evidence is dated samples of real occurrences. **A control that fails design cannot pass operation.** The four techniques, weakest to strongest, are **inquiry, observation, inspection and re-performance**, and **inquiry alone is never sufficient evidence**.

**Workpapers.** A workpaper is the auditor's record of one test, and the evidence that the audit itself was done properly. It carries the objective, the criteria, the population and how it was derived, the sample size and method, the test steps, the evidence reference, the results of design and operating tests, the conclusion, the finding rating and the preparer and reviewer. The test of a good one: could a different auditor pick it up, re-run the test and reach the same conclusion?

**Finding ratings.** A **major nonconformity** is a requirement that is absent or has broken down systemically, and it blocks certification until the correction is verified. A **minor nonconformity** is an isolated lapse against a requirement that otherwise works. An **OFI** — opportunity for improvement — is advice, not a nonconformity. The short test: **absent is major, slipped is minor, could-be-better is an OFI.**

## 1.9 How SOC 2 differs from ISO/IEC 27001, and why both are being run

The overlap is large at the level of *evidence* and small at the level of *artefacts*. One quarterly access review record serves A.5.18 and CC6.3 equally well. But ISO requires a management system — scope, leadership, objectives, internal audit, management review, corrective action — that SOC 2 never asks for, and SOC 2 requires a system description, a management assertion and complementary user entity controls that ISO has no concept of. Part 2.5 measures the overlap precisely: **77 of the 88 applicable Annex A controls have a criterion counterpart, 11 do not, and 7 clause requirements have no SOC 2 counterpart at all.**

The commercial reason to run both is simpler. Cypher Group Inc. sells to ~200 SMB customers in Europe, where a public ISO certificate answers most procurement questions cheaply. SOC 2 becomes necessary the moment a US or enterprise buyer asks for it, and that buyer will not accept an ISO certificate in its place. The sequence in Part 7 does ISO first and reuses its evidence for SOC 2, rather than running two programmes side by side.

---

# Part 2 — Criteria selection and the crosswalk

## 2.1 Which Trust Services categories are in scope, and why

The choice is justified against CGI-RSK-001 v1.1 — R-001 to R-005 and VR-001 to VR-009 — not against what looks impressive on a trust page. **An asserted category the organisation cannot evidence is worse than a category honestly left out.**

### Security (Common Criteria CC1-CC9)

| Field | Value |
|---|---|
| Trust Services category | Security (Common Criteria CC1-CC9) |
| Decision | IN - mandatory |
| Justification traced to CGI-RSK-001 v1.1 | Required in every SOC 2 engagement. Carries R-001 phishing, R-002 ransomware, R-003 insider exfiltration, R-004 production API authorisation flaw and R-005 CloudCo misconfiguration, plus VR-001 to VR-009. Thirty-three criteria. |

### Availability (A1)

| Field | Value |
|---|---|
| Trust Services category | Availability (A1) |
| Decision | IN - with a precondition |
| Justification traced to CGI-RSK-001 v1.1 | Approximately 200 customers run project delivery on the platform; unavailability is the loss they feel first. R-002 (ransomware) and VR-002 (five vendors sharing CloudCo with the platform) both carry availability impact, and CG-01 (backup, recovery and restore testing) is still open. PRECONDITION: A1 asks whether the system is available 'as committed'. Assumption ISO-A04 records that no contractual SLA figure exists anywhere in Projects 1-4. Service commitments must be published (SOC-05) before Availability can be included in a real engagement. |

### Confidentiality (C1)

| Field | Value |
|---|---|
| Trust Services category | Confidentiality (C1) |
| Decision | IN |
| Justification traced to CGI-RSK-001 v1.1 | Customer account data, project content, payment metadata and internal documents are held for business customers under contract. R-003 (insider exfiltration) and VR-008 are confidentiality risks, CG-05 (data loss prevention) is open, and CGI-POL-004 already defines four classification tiers and a handling matrix. Two criteria. |

### Processing Integrity (PI1)

| Field | Value |
|---|---|
| Trust Services category | Processing Integrity (PI1) |
| Decision | OUT |

| Field | Value |
|---|---|
| Justification traced to CGI-RSK-001 v1.1 | PI1 asks whether processing is complete, valid, accurate, timely and authorised. The platform manages project and task records that customers enter and control; it performs no calculation or transaction processing on their behalf, and payment processing belongs to PaymentsCo (CGI-POL-004 s4.1.4 and AVD-001 confirm no card numbers are held). No risk in CGI-RSK-001 v1.1 concerns processing completeness or accuracy. Including PI1 would assert something no customer has asked for and no risk supports. |

**Privacy (P1-P8)**

| Field | Value |
|---|---|
| Trust Services category | Privacy (P1-P8) |
| Decision | OUT - for the first report |
| Justification traced to CGI-RSK-001 v1.1 | Privacy covers notice, choice and consent, collection, use and retention, access, disclosure, quality and monitoring for personal information. Cypher Group Inc. acts mainly as a processor for its customers, and the GDPR foundations are the weakest evidence in the estate: six of seventeen vendors have no DPA, there is no Article 30 record of processing, no transfer register and no executed retention schedule. Asserting Privacy now would place the examination on the ground where the organisation is least able to support it. Add P1-P8 at the second Type II, after ISO-09 completes. |

**Result: 38 criteria in scope** — 33 Common Criteria (CC1 to CC9), 3 Availability (A1) and 2 Confidentiality (C1).

## 2.2 The method, published before any score

| Element | Rule | Why |
|---|---|---|
| Source maturity | Each mapped Annex A control carries its CGI-ISO-001 maturity, 0–4. Clause requirements score 0–2 and convert **0 → 0, 1 → 2, 2 → 3** | One scale, stated once. Clause 1 means "designed, not evidenced", which is a 2 on the GAP scale; clause 2 means "met with evidence", which is a 3 |
| **Criterion Readiness Level (CRL)** | The **mean** of all mapped item maturities, banded: **< 0.5 → 0 · 0.5–1.49 → 1 · 1.5–2.49 → 2 · ≥ 2.5 → 3** | A criterion is an outcome served by several controls. One strong control does not carry a criterion, and one weak control does not sink it |
| CRL meaning | 0 Absent · 1 Documented only · 2 Designed and implemented, no operating evidence · 3 Operating with evidence | The same ladder as the Q1/Q2/Q3 test in Part 1.8 |
| **Design verdict** | **Adequate** only if CRL ≥ 2 **and** no mapped control sits at maturity 0 | A single zero is a hole in the design, whatever the average says. This is the rule that catches A.8.3 inside CC6.3 |
| **Operating verdict** | **Evidenced** only at CRL 3 | Design never implies operation |
| Type I readiness | Σ min(CRL, 2) ÷ (38 × 2) = **41 / 76** | A Type I asks about design and implementation, so CRL 3 earns no extra credit |
| Type II readiness | Σ CRL ÷ (38 × 3) = **41 / 114** | A Type II asks about operation, so the full range counts |
| **Gate override** | **If any gate fails, the answer is NO-GO whatever the percentage** | Same principle as the CGI-TPR-001 vendor veto and the CGI-ISO-001 Stage 1 gates: a score without a veto can be gamed by breadth |
| Bands | ≥ 85% and no gate failure = Ready · 60–84% = Ready within 90 days · < 60% = Not ready | |

## 2.3 What each criterion asks

| Criterion | Group | What it asks (paraphrased) |
|---|---|---|
| **CC1.1** | CC1 Control Environment | The entity demonstrates a commitment to integrity and ethical values |
| **CC1.2** | CC1 Control Environment | The board of directors demonstrates independence from management and exercises oversight |
| **CC1.3** | CC1 Control Environment | Management establishes structures, reporting lines, and appropriate authorities and responsibilities |

| Criterion | Group | What it asks (paraphrased) |
|---|---|---|
| **CC1.4** | CC1 Control Environment | The entity demonstrates a commitment to attract, develop and retain competent individuals |
| **CC1.5** | CC1 Control Environment | The entity holds individuals accountable for their internal control responsibilities |
| **CC2.1** | CC2 Communication and Information | The entity obtains or generates and uses relevant, quality information to support internal control |
| **CC2.2** | CC2 Communication and Information | The entity internally communicates information, including objectives and responsibilities for internal control |
| **CC2.3** | CC2 Communication and Information | The entity communicates with external parties regarding matters affecting internal control |
| **CC3.1** | CC3 Risk Assessment | The entity specifies objectives with sufficient clarity to enable identification and assessment of risks |
| **CC3.2** | CC3 Risk Assessment | The entity identifies risks to the achievement of its objectives and analyses them as a basis for management |
| **CC3.3** | CC3 Risk Assessment | The entity considers the potential for fraud in assessing risks |
| **CC3.4** | CC3 Risk Assessment | The entity identifies and assesses changes that could significantly affect the system of internal control |
| **CC4.1** | CC4 Monitoring Activities | The entity selects, develops and performs ongoing and separate evaluations of internal control |
| **CC4.2** | CC4 Monitoring Activities | The entity evaluates and communicates internal control deficiencies in a timely manner |
| **CC5.1** | CC5 Control Activities | The entity selects and develops control activities that mitigate risks to acceptable levels |
| **CC5.2** | CC5 Control Activities | The entity selects and develops general control activities over technology |
| **CC5.3** | CC5 Control Activities | The entity deploys control activities through policies and procedures that put them into action |
| **CC6.1** | CC6 Logical and Physical Access Controls | The entity implements logical access security software, infrastructure and architectures over protected information assets |
| **CC6.2** | CC6 Logical and Physical Access Controls | Prior to issuing credentials, the entity registers and authorises new internal and external users |
| **CC6.3** | CC6 Logical and Physical Access Controls | The entity authorises, modifies or removes access based on roles, responsibilities and least privilege |
| **CC6.4** | CC6 Logical and Physical Access Controls | The entity restricts physical access to facilities and protected information assets |
| **CC6.5** | CC6 Logical and Physical Access Controls | The entity discontinues logical and physical protections over physical assets only after ability to read data has been diminished |
| **CC6.6** | CC6 Logical and Physical Access Controls | The entity implements logical access security measures against threats from sources outside its system boundaries |
| **CC6.7** | CC6 Logical and Physical Access Controls | The entity restricts the transmission, movement and removal of information and protects it during transmission and removal |
| **CC6.8** | CC6 Logical and Physical Access Controls | The entity implements controls to prevent or detect and act upon the introduction of unauthorised or malicious software |
| **CC7.1** | CC7 System Operations | The entity uses detection and monitoring procedures to identify configuration changes and new vulnerabilities |
| **CC7.2** | CC7 System Operations | The entity monitors system components for anomalies indicative of malicious acts, natural disasters and errors |
| **CC7.3** | CC7 System Operations | The entity evaluates security events to determine whether they could or have resulted in a failure to meet objectives |
| **CC7.4** | CC7 System Operations | The entity responds to identified security incidents by executing a defined incident-response programme |

| Criterion | Group | What it asks (paraphrased) |
|---|---|---|
| **CC7.5** | CC7 System Operations | The entity identifies, develops and implements activities to recover from identified security incidents |
| **CC8.1** | CC8 Change Management | The entity authorises, designs, develops or acquires, configures, documents, tests, approves and implements changes |
| **CC9.1** | CC9 Risk Mitigation | The entity identifies, selects and develops risk mitigation activities for risks arising from potential business disruptions |
| **CC9.2** | CC9 Risk Mitigation | The entity assesses and manages risks associated with vendors and business partners |
| **A1.1** | A1 Availability | The entity maintains, monitors and evaluates current processing capacity and use of system components |
| **A1.2** | A1 Availability | The entity authorises, designs, develops, implements, operates, approves, maintains and monitors environmental protections, software, data back-up processes and recovery infrastructure |
| **A1.3** | A1 Availability | The entity tests recovery plan procedures supporting system recovery |
| **C1.1** | C1 Confidentiality | The entity identifies and maintains confidential information to meet objectives related to confidentiality |
| **C1.2** | C1 Confidentiality | The entity disposes of confidential information to meet objectives related to confidentiality |

## 2.4 The crosswalk — every applicable criterion

Maturities in brackets are the CGI-ISO-001 v1.0 values; clause scores in brackets are the CGI-ISO-001 Part 4 values. The complete 18-column version, including the points of focus and the design holes, is `06-soc2-readiness-and-internal-audit.csv` and sheet `01_TSC_Crosswalk` of the workbook, where every score is a live formula over `02_Crosswalk_Map`.

| Criterion | Mapped ISO 27001 Annex A controls (maturity) | Mapped clauses (score) | Items | Mean | CRL | Design | Operating | Gate |
|---|---|---|---|---|---|---|---|---|
| **CC1.1** | A.5.1 (2); A.5.4 (1); A.6.2 (0); A.6.4 (0); A.6.6 (0) | 5.1 (1); 5.2 (1) | 7 | 1.00 | **1** | Deficient | Not evidenced | - |
| **CC1.2** | A.5.2 (2); A.5.35 (0); A.5.36 (1) | 5.1 (1); 9.3.1 (0) | 5 | 1.00 | **1** | Deficient | Not evidenced | SG-2 |
| **CC1.3** | A.5.2 (2); A.5.3 (1) | 5.3 (1); 5.1 (1) | 4 | 1.75 | **2** | Adequate | Not evidenced | - |
| **CC1.4** | A.6.1 (1); A.6.3 (1) | 7.2 (0); 7.3 (1) | 4 | 1.00 | **1** | Deficient | Not evidenced | - |
| **CC1.5** | A.5.4 (1); A.5.36 (1); A.6.4 (0) | 5.3 (1) | 4 | 1.00 | **1** | Deficient | Not evidenced | - |
| **CC2.1** | A.5.9 (1); A.5.7 (0); A.8.15 (1) | 9.1 (1) | 4 | 1.00 | **1** | Deficient | Not evidenced | - |
| **CC2.2** | A.5.1 (2); A.5.10 (2); A.6.3 (1); A.6.8 (2) | 7.3 (1); 7.4 (1) | 6 | 1.83 | **2** | Adequate | Not evidenced | - |
| **CC2.3** | A.5.5 (1); A.5.14 (2); A.5.20 (2); A.6.6 (0) | 7.4 (1); 4.2 (1) | 6 | 1.50 | **2** | Deficient | Not evidenced | SG-3 |
| **CC3.1** | A.5.1 (2) | 6.2 (0); 4.1 (1) | 3 | 1.33 | **1** | Deficient | Not evidenced | - |
| **CC3.2** | A.5.7 (0); A.8.8 (0) | 6.1.2 (1); 8.2 (2) | 4 | 1.25 | **1** | Deficient | Not evidenced | SG-4 |
| **CC3.3** | A.5.4 (1); A.6.1 (1); A.8.2 (2); A.8.16 (0) | 6.1.2 (1) | 5 | 1.20 | **1** | Deficient | Not evidenced | - |
| **CC3.4** | A.5.8 (0); A.8.32 (0) | 6.3 (0); 8.2 (2) | 4 | 0.75 | **1** | Deficient | Not evidenced | - |
| **CC4.1** | A.5.35 (0); A.5.36 (1); A.8.16 (0) | 9.1 (1); 9.2.1 (0); 9.2.2 (0) | 6 | 0.50 | **1** | Deficient | Not evidenced | - |
| **CC4.2** | A.5.27 (1); A.5.36 (1) | 9.3.2 (0); 10.2 (0) | 4 | 0.50 | **1** | Deficient | Not evidenced | - |

| Criterion | Mapped ISO 27001 Annex A controls (maturity) | Mapped clauses (score) | Items | Mean | CRL | Design | Operating | Gate |
|---|---|---|---|---|---|---|---|---|
| **CC5.1** | A.5.1 (2) | 6.1.3 (1) | 2 | 2.00 | **2** | Adequate | Not evidenced | - |
| **CC5.2** | A.8.9 (0); A.8.20 (0); A.8.32 (0) | 8.1 (1) | 4 | 0.50 | **1** | Deficient | Not evidenced | - |
| **CC5.3** | A.5.1 (2); A.5.36 (1); A.5.37 (1) | 5.2 (1); 7.5 (1) | 5 | 1.60 | **2** | Adequate | Not evidenced | - |
| **CC6.1** | A.5.15 (2); A.5.16 (2); A.8.2 (2); A.8.3 (0); A.8.5 (2); A.8.20 (0); A.8.22 (0) | 8.1 (1) | 8 | 1.25 | **1** | Deficient | Not evidenced | SG-5 |
| **CC6.2** | A.5.16 (2); A.5.17 (2); A.5.18 (2); A.6.5 (1) | - | 4 | 1.75 | **2** | Adequate | Not evidenced | SG-5 |
| **CC6.3** | A.5.3 (1); A.5.11 (2); A.5.15 (2); A.5.18 (2); A.6.5 (1); A.8.2 (2); A.8.3 (0) | - | 7 | 1.43 | **1** | Deficient | Not evidenced | SG-5 |
| **CC6.4** | A.7.1 (0); A.7.2 (0); A.7.3 (0) | - | 3 | 0.00 | **0** | Deficient | Not evidenced | - |
| **CC6.5** | A.7.10 (2); A.7.14 (0) | - | 2 | 1.00 | **1** | Deficient | Not evidenced | - |
| **CC6.6** | A.8.5 (2); A.8.20 (0); A.8.21 (0); A.8.22 (0); A.8.23 (0) | - | 5 | 0.40 | **0** | Deficient | Not evidenced | - |
| **CC6.7** | A.5.14 (2); A.7.10 (2); A.8.10 (1); A.8.11 (0); A.8.12 (0); A.8.24 (0) | - | 6 | 0.83 | **1** | Deficient | Not evidenced | - |
| **CC6.8** | A.8.7 (0); A.8.18 (0); A.8.19 (0) | - | 3 | 0.00 | **0** | Deficient | Not evidenced | - |
| **CC7.1** | A.8.8 (0); A.8.9 (0); A.8.32 (0) | - | 3 | 0.00 | **0** | Deficient | Not evidenced | - |
| **CC7.2** | A.5.25 (1); A.8.15 (1); A.8.16 (0); A.8.17 (0) | 9.1 (1) | 5 | 0.80 | **1** | Deficient | Not evidenced | - |
| **CC7.3** | A.5.24 (2); A.5.25 (1) | - | 2 | 1.50 | **2** | Adequate | Not evidenced | - |
| **CC7.4** | A.5.5 (1); A.5.24 (2); A.5.26 (2); A.5.28 (1); A.6.8 (2) | - | 5 | 1.60 | **2** | Adequate | Not evidenced | SG-6 |
| **CC7.5** | A.5.27 (1); A.5.29 (1); A.5.30 (1); A.8.13 (1) | 10.2 (0) | 5 | 0.80 | **1** | Deficient | Not evidenced | - |
| **CC8.1** | A.8.4 (0); A.8.19 (0); A.8.25 (0); A.8.26 (0); A.8.28 (0); A.8.29 (0); A.8.31 (0); A.8.32 (0); A.8.33 (0) | 6.3 (0) | 10 | 0.00 | **0** | Deficient | Not evidenced | SG-7 |
| **CC9.1** | A.5.29 (1); A.5.30 (1); A.8.6 (0); A.8.14 (0) | 6.1.3 (1) | 5 | 0.80 | **1** | Deficient | Not evidenced | - |
| **CC9.2** | A.5.19 (2); A.5.20 (2); A.5.21 (2); A.5.22 (2); A.5.23 (1); A.5.34 (1) | 8.1 (1) | 7 | 1.71 | **2** | Adequate | Not evidenced | SG-8 |
| **A1.1** | A.8.6 (0); A.8.16 (0) | - | 2 | 0.00 | **0** | Deficient | Not evidenced | - |
| **A1.2** | A.5.30 (1); A.7.5 (0); A.8.13 (1); A.8.14 (0) | - | 4 | 0.50 | **1** | Deficient | Not evidenced | - |
| **A1.3** | A.5.27 (1); A.5.30 (1); A.8.13 (1) | - | 3 | 1.00 | **1** | Deficient | Not evidenced | - |
| **C1.1** | A.5.9 (1); A.5.12 (2); A.5.13 (1); A.5.33 (0) | - | 4 | 1.00 | **1** | Deficient | Not evidenced | - |
| **C1.2** | A.5.33 (0); A.7.10 (2); A.7.14 (0); A.8.10 (1) | - | 4 | 0.75 | **1** | Deficient | Not evidenced | - |

## 2.5 Where one control satisfies both frameworks, and where it does not

**77 of the 88 applicable Annex A controls map to at least one criterion.** For those, one control and one piece of evidence serve both frameworks — the quarterly access review record, the vendor assessment file, the incident ticket, the restore test report. That is the whole argument for maintaining **one** control set with two labels rather than two programmes.

**11 applicable Annex A controls have no criterion counterpart.** They appear inside points of focus at most, and points of focus are not requirements, so doing them earns no SOC 2 credit:

| Annex A control | Title | Maturity | Why SOC 2 gives no credit |
|---|---|---|---|
| A.5.6 | Contact with special interest groups | 0 | Appears only inside a point of focus, which is not a requirement. |
| A.5.31 | Legal, statutory, regulatory and contractual requirements | 1 | Appears only inside a point of focus, which is not a requirement. |
| A.5.32 | Intellectual property rights | 0 | Appears only inside a point of focus, which is not a requirement. |
| A.6.7 | Remote working | 2 | Appears only inside a point of focus, which is not a requirement. |
| A.7.7 | Clear desk and clear screen | 2 | Appears only inside a point of focus, which is not a requirement. |
| A.7.8 | Equipment siting and protection | 0 | Appears only inside a point of focus, which is not a requirement. |
| A.7.9 | Security of assets off-premises | 1 | Appears only inside a point of focus, which is not a requirement. |
| A.7.13 | Equipment maintenance | 0 | Appears only inside a point of focus, which is not a requirement. |
| A.8.1 | User endpoint devices | 1 | Appears only inside a point of focus, which is not a requirement. |
| A.8.27 | Secure system architecture and engineering principles | 0 | Appears only inside a point of focus, which is not a requirement. |
| A.8.34 | Protection of information systems during audit testing | 0 | Appears only inside a point of focus, which is not a requirement. |

**7 ISO clause requirements have no counterpart at all**, and they are not a random assortment — they are the management system:

| Clause | Requirement | Score | Why there is no counterpart |
|---|---|---|---|
| 4.3 | Determining the scope of the ISMS | 1 | SOC 2 does not require a management system. |
| 4.4 | Information security management system | 1 | SOC 2 does not require a management system. |
| 6.1.1 | Actions to address risks and opportunities - general | 0 | SOC 2 does not require a management system. |
| 7.1 | Resources | 1 | SOC 2 does not require a management system. |
| 8.3 | Information security risk treatment (performance) | 1 | SOC 2 does not require a management system. |
| 9.3.3 | Management review results | 0 | SOC 2 does not require a management system. |
| 10.1 | Continual improvement | 1 | SOC 2 does not require a management system. |

**And the reverse.** Four things SOC 2 requires that no ISO action would ever produce:

| SOC 2 requirement | Why ISO never produces it |
|---|---|
| **CC1.2** — a governing body independent of management, exercising oversight | ISO clause 5 requires leadership, which the CEO supplies. It does not require independence *from* management, and no Annex A control creates an oversight body |
| **CC2.3** — communicating commitments and responsibilities (the CUECs) to user entities | ISO/IEC 27001 has no concept of a complementary user entity control |
| **CC3.3** — consideration of the potential for fraud | ISO/IEC 27001:2022 Annex A contains no fraud control. Nothing in the SoA, the risk register or REC-01 to REC-18 would ever surface this |
| **The system description and management's assertion** | The SoA lists controls; it is not a description of the system, its boundaries or its commitments, and nobody asserts anything before an ISO audit |

These four are conflicts **SC-03, SC-04 and SC-05** in Part 7, and they generate three new actions that exist only because SOC 2 was crosswalked rather than assumed.

### 2.6 What the crosswalk found

| CRL | Meaning | Criteria | Which |
|---|---|---|---|
| 3 | Operating with evidence | 0 | - |
| 2 | Designed and implemented, no operating evidence | 9 | CC1.3, CC2.2, CC2.3, CC5.1, CC5.3, CC6.2, CC7.3, CC7.4, CC9.2 |
| 1 | Documented only | 23 | CC1.1, CC1.2, CC1.4, CC1.5, CC2.1, CC3.1, CC3.2, CC3.3, CC3.4, CC4.1, CC4.2, CC5.2, CC6.1, CC6.3, CC6.5, CC6.7, CC7.2, CC7.5, CC9.1, A1.2, A1.3, C1.1, C1.2 |
| 0 | Absent | 6 | CC6.4, CC6.6, CC6.8, CC7.1, CC8.1, A1.1 |

Three observations worth stating plainly.

**First, the shape follows the Statement of Applicability exactly, and it should.** Zero controls are Implemented, so the highest maturity anywhere in the estate is 2 and **no criterion can reach CRL 3**. The 9 criteria at CRL 2 are precisely those served by the approved policy pack and the vendor programme — the two places where Projects 1 and 4 did real work.

**Second, the design verdict is harsher than the average, and that is the point.** 8 criteria have an adequate design against 9 at CRL 2, because **CC2.3 reaches CRL 2 on the average while carrying A.6.6 at maturity 0** — no confidentiality agreements are on file. An examiner does not average; they find the hole.

**Third, CC8.1 is the worst criterion in the report and it is not close.** Ten mapped controls, every one at maturity 0, giving a mean of 0.00. Change management is where R-004 lives, and a Type II examiner would test CC8.1 early, find no change record at all, and stop.

---

## Part 3 — System description, CUECs and CSOCs

This part is written **as management**, because Section 3 of a SOC 2 report is management's own description. It is a draft for CEO approval (action **SOC-02**), not an approved document.

### 3.1 Draft system description

#### A. The company and the service

Cypher Group Inc. is a fifty-person business-to-business software company that provides a cloud-based project-management platform to approximately 200 small and medium-sized business customers. Customers use the platform to create projects and tasks, assign work, store project documents and track delivery. The company operates from a single head office and supports remote and home working under CGI-POL-001 section 4.4.

#### B. Principal service commitments and system requirements

> **This section cannot be completed today.** Assumption ISO-A04 records that no contractual service level figure exists anywhere in Projects 1 to 4. The Availability category asks whether the system is available *as committed*; with no commitment there is nothing to examine against. Action **SOC-05** publishes the commitments below before any engagement includes A1.

| Commitment type | What must be stated before a SOC 2 engagement | Status |
|---|---|---|
| Availability | Monthly uptime target, measurement method, exclusions for planned maintenance | **Not defined** |
| Recovery | Recovery time objective and recovery point objective | **Not defined** — CG-01 open; VRA-2026-001 condition C4 due 15 Dec 2026 |

| Commitment type | What must be stated before a SOC 2 engagement | Status |
|---|---|---|
| Security | Encryption in transit and at rest, MFA availability, access logging, breach notification timeframe | Partly stated across CGI-POL-002, -004 and -005; not stated to customers |
| Confidentiality | Classification tiers accepted, retention and deletion windows, sub-processor disclosure | Defined internally in CGI-POL-004; not stated to customers |
| Support | Response and resolution targets by severity | **Not defined** |

### C. Components of the system

| Component | In the system |
|---|---|
| **Infrastructure** | CloudCo production accounts, primary region `eu-central-1`, backup copies in `us-east-1`; managed compute, storage, database and networking services |
| **Software** | The Cypher Group Inc. platform application and its supporting services; CodeCo for source control; LoginCo and OfficeCo for identity; MonitorCo for application performance monitoring |
| **People** | All fifty employees across leadership, engineering, IT operations, customer success, people and operations, and finance. At this size every function touches customer or platform data |
| **Procedures** | CGI-POL-001 to -005 v1.0; the CGI-TPR-001 vendor workflow; the CGI-RSK-001 risk process. Documented operating procedures beneath the policies **do not yet exist** (A.5.37, OFI-14) |
| **Data** | Customer account data, project content created by customers, payment metadata (no card numbers — CGI-POL-004 section 4.1.4 and AVD-001), internal documents, employee data, limited personal data |

### D. Boundaries of the system

**Inside the boundary:** the platform and its CloudCo environment, the source code and its pipeline, the identity layer, customer support handling of customer data, and the people, policies and procedures that operate them.

**Outside the boundary:** the internal controls of the seventeen vendors in CGI-TPR-001, which are managed as interfaces under A.5.19 to A.5.23; cardholder data, which is never held; and anything a customer does inside their own tenant or on their own devices, which is covered by the CUECs in 3.2.

### E. Subservice organisation and the carve-out

**CloudCo (CGI-VEN-001) is carved out.** Its controls are excluded from this description and from the examiner's testing. Users of a report on this system must read CloudCo's own assurance reports to understand those controls, and must consider the complementary subservice organisation controls listed in 3.3. CloudCo holds SOC 2 Type II, ISO/IEC 27001, 27017 and 27018 per VRA-2026-001 (invented for the scenario).

The inclusive method was considered and rejected: it requires the subservice organisation to participate in the examination, which no hyperscale provider offers at this scale. The carve-out is disclosed here rather than left implicit, because **an undisclosed carve-out is the single most common defect in a small company's first system description.**

ChatCo, PaymentsCo, OfficeCo and the remaining vendors are treated as **vendors**, not subservice organisations: they support the business rather than delivering the service the customer buys. This classification is a judgement that the examining CPA firm will test, and it should be revisited if ChatCo becomes part of the customer-facing support path.

### F. Significant changes during the period

None. The ISMS did not exist before September 2026. The control set described here was created by CGI-POL-001 to -005, CGI-RSK-001, CGI-GAP-001, CGI-TPR-001 and CGI-ISO-001 between 7 and 16 September 2026.

### G. Criteria not applicable

Processing Integrity (PI1) and Privacy (P1 to P8) are excluded, with the reasoning in Part 2.1. The description would state the exclusion and the reason, because **a reader must be able to see what was not examined.**

## 3.2 Cypher Group Inc.'s own complementary user entity controls

These are the controls the company's ~200 customers must perform for its controls to work. Each one exists because there is something the platform genuinely cannot know or do.

| CUEC | Area | The control the customer must perform | Why our control depends on it | Criteria |
|---|---|---|---|---|
| **CUEC-01** | Account administration | User entities are responsible for designating at least two administrators for their tenant and for keeping the designated administrator list current. | Cypher Group Inc. acts on instructions from designated administrators only. If the list is stale, an instruction from a former administrator cannot be distinguished from a valid one. | CC6.2, CC6.3 |
| **CUEC-02** | Authentication | User entities are responsible for enabling multi-factor authentication for all of their users, and for requiring phishing-resistant factors for their administrators. | The platform offers MFA; it does not force it. R-001 (phishing) lands on customer accounts through customer credentials, outside Cypher Group Inc.'s control. | CC6.1, CC6.2, CC6.6 |
| **CUEC-03** | Access review | User entities are responsible for reviewing their own users' access rights and roles at least quarterly and for removing access that is no longer required. | Cypher Group Inc. cannot know which of a customer's staff have left. Role assignment inside a tenant is a customer decision. | CC6.2, CC6.3 |
| **CUEC-04** | Joiner, mover, leaver | User entities are responsible for removing or disabling their users promptly when those users leave or change role, using the administrative console or the provisioning interface. | Deprovisioning is initiated by the customer. Cypher Group Inc. executes it; it does not trigger it. | CC6.2, CC6.3 |
| **CUEC-05** | Log review | User entities are responsible for reviewing the tenant audit log made available to them and for reporting anomalies to Cypher Group Inc. support. | Detection of misuse by a customer's own users depends on someone who knows what normal looks like inside that tenant. | CC7.2, CC7.3 |
| **CUEC-06** | Incident notification | User entities are responsible for reporting suspected security incidents affecting their tenant to Cypher Group Inc. without undue delay, using the published channel. | The incident clock in CGI-POL-005 s5.6.3 (GDPR 72 hours) starts when Cypher Group Inc. becomes aware. A customer who delays reporting consumes that budget. | CC7.3, CC7.4 |
| **CUEC-07** | Data classification and content | User entities are responsible for determining what data they upload to the platform, and for not placing special categories of personal data, payment card numbers or regulated records in project content. | The platform is classified for customer account data, project content and limited personal data. It is not designed or assessed for special-category or cardholder data. | C1.1, CC6.7 |
| **CUEC-08** | Integrations and API keys | User entities are responsible for authorising, storing and rotating their own API keys and third-party integrations, and for revoking them when no longer required. | A customer-issued key carries the customer's authorisation. Cypher Group Inc. honours it and cannot judge whether it is still wanted. | CC6.1, CC6.6, CC9.2 |
| **CUEC-09** | Retention and deletion instructions | User entities are responsible for issuing deletion or export instructions within their contractual window, and for retaining their own copies of exported data. | Deletion is performed on instruction. Retention beyond the platform is outside the system boundary. | C1.2 |
| **CUEC-10** | Endpoint and network security | User entities are responsible for the security of the devices and networks their users use to reach the platform. | Session hijacking or credential theft on a customer endpoint is indistinguishable at the platform from legitimate use. | CC6.1, CC6.6 |

**How these must be communicated (criterion CC2.3).** Writing CUECs is not communicating them. They belong in the customer agreement, in the onboarding pack and on the trust page, and the examiner will test that the communication happened. Today **none of the ten has been communicated to any customer** — that is finding **OFI-10**, and it is why gate **SG-3** fails.

### 3.3 Complementary subservice organisation controls — CloudCo

| CSOC | Control CloudCo is relied on to perform | Criteria | Assurance held |
|---|---|---|---|
| **CSOC-01** | Physical and environmental security of the data centres hosting the platform, including physical access control, monitoring, power and cooling. | CC6.4, A1.2 | SOC 2 Type II, ISO/IEC 27001, 27017 and 27018 held per VRA-2026-001 (invented for the scenario). Basis for excluding A.7.4, A.7.6, A.7.11 and A.7.12 from the SoA. |
| **CSOC-02** | Secure disposal and destruction of storage media at end of life. | CC6.5 | As CSOC-01. |
| **CSOC-03** | Availability of the underlying compute, storage, network and managed database services, and of the regional infrastructure. | A1.1, A1.2 | As CSOC-01. VR-002 records the concentration: five further vendors share CloudCo with the platform. |
| **CSOC-04** | Patching and maintenance of the managed services under the provider's side of the shared-responsibility model. | CC7.1, CC8.1 | As CSOC-01. The boundary itself is undocumented (A.5.23 = maturity 1; action ISO-02). |
| **CSOC-05** | Encryption of data at rest in managed services where provider-managed keys are used, and of data in transit within the provider network. | CC6.7 | As CSOC-01. CGI has no cryptography standard of its own (A.8.24 Not started), so the provider control is currently the only one. |
| **CSOC-06** | Logical access controls over the provider's own personnel accessing the infrastructure. | CC6.1, CC6.3 | As CSOC-01. |

### 3.4 The mirror: reconciling our CUECs with the CloudCo CUECs we have not accepted

CGI-TPR-001 assessed CloudCo and returned **PASS WITH CONDITIONS at 89%**, with four conditions, **all of them Cypher Group Inc.'s own**. Three came from a single place: the complementary user entity controls at the back of the CloudCo SOC 2 report — the controls the provider's auditor **assumed the customer was performing** when forming a clean opinion. Finding **F-010** records that they are unaccepted and unassigned.

Cypher Group Inc. is now on the other side of the same transaction. Here is what that looks like set side by side:

| The CUEC we write for our ~200 customers | The CloudCo CUEC it mirrors | Our own status as a customer | SoA position |
|---|---|---|---|
| CUEC-02 - customers must enable MFA, phishing-resistant for administrators | CloudCo CUEC 2 - MFA on the root account and restricted root use | **UNACCEPTED. F-010; no owner assigned; condition C1 open until 15 Dec 2026.** | A.8.2 maturity 2 (policy only); A.5.23 maturity 1 |
| CUEC-03 - customers must review their users' access at least quarterly | CloudCo CUEC 3 - least-privilege IAM with periodic review | **NEVER PERFORMED. CGI-POL-003 s4.7.1 mandates a quarterly privileged review; zero have run (OFI-15).** | A.5.18 maturity 2 (mandated, never evidenced) |
| CUEC-05 - customers must review the tenant audit log and report anomalies | CloudCo CUEC 1 - organisation-wide CloudTrail with log file validation | **UNVERIFIED. No central security log account, no retention standard, no alert rules (OFI-03).** | A.8.15 maturity 1; A.8.16 maturity 0 |
| CUEC-07 - customers are responsible for classifying the data they upload | CloudCo CUEC 4 - encryption management for customer-controlled data | **NO STANDARD. CGI-POL-004 says where encryption is required; no algorithms, TLS minimum or key management exist.** | A.8.24 maturity 0 |

**Four CUECs written for customers. Four CloudCo CUECs ignored. The match is one to one.**

This is not a coincidence, and it is the most useful finding in this assessment. The four things a provider cannot do for a customer — force MFA, review the customer's own access, read the customer's own logs, decide how the customer's data should be protected — are the same four at every layer of the stack. Cypher Group Inc. has understood them perfectly **as a seller** and not at all **as a buyer**.

The consequence is concrete. A customer who reads the CUEC schedule in 3.2 and asks *"what did you do with the CUECs your own provider gave you?"* has found a hole in the system description, because **a description is only as**

**honest as the layer beneath it.** In criteria terms this is a **CC1.1 and CC1.5 control-environment problem** — tone and accountability — long before it is a technical one, and it is the documented reason A.5.23 sits at maturity 1 while A.5.19 to A.5.22 sit at 2.

**Resolution.** Condition **C1** of VRA-2026-001 is due 15 December 2026 and requires a signed CUEC acceptance record naming four owners. It is already in the plan. What this assessment adds is the rule that follows from it:

> **Never publish a CUEC schedule to customers until the CUEC schedules of your own subservice organisations have been accepted and assigned.** Action SOC-02 is therefore dependent on condition C1, not parallel to it.

---

## Part 4 — Readiness gap assessment and go/no-go

### 4.1 The gates

A gate is a requirement whose absence makes the engagement impossible rather than merely weak. Eight were set before scoring began. A gate passes only when the criterion reaches **CRL ≥ 2** *and* its design is **Adequate** — that is, no mapped control sits at maturity 0.

| Gate | Requirement | Criteria tested | Why it is a gate | Result |
|---|---|---|---|---|
| SG-1 | Management assertion and system description prepared and approved | - | Without management's description and assertion there is no engagement to perform (AT-C 205). | **FAIL** |
| SG-2 | CC1.2 - independent oversight of the system of internal control | CC1.2 | The control environment has no apex: no board, no governing body, no independent review. | **FAIL** |
| SG-3 | CC2.3 - external communication of commitments and CUECs | CC2.3 | Nothing has been communicated to user entities, so there is no commitment to attest against. | **FAIL** |
| SG-4 | CC3.2 - risk identification and analysis | CC3.2 | Every other criterion is scoped from the risk assessment. | **FAIL** |
| SG-5 | CC6.1, CC6.2, CC6.3 - logical access | CC6.1, CC6.2, CC6.3 | Logical access is the core of the Security category; a design failure here is fatal to the report. | **FAIL** |
| SG-6 | CC7.4 - incident response | CC7.4 | An unhandled incident invalidates every other assertion in the period. | **PASS** |
| SG-7 | CC8.1 - change management | CC8.1 | Unmanaged change means no design assertion survives the period. R-004 lives here. | **FAIL** |
| SG-8 | CC9.2 - vendor and business partner risk management | CC9.2 | CloudCo is carved out; without vendor controls the carve-out is a hole, not a boundary. | **PASS** |

**6 of 8 gates fail.** The two that pass are worth naming, because they are the direct output of earlier projects: **SG-6 (CC7.4, incident response)** passes on the strength of CGI-POL-005, and **SG-8 (CC9.2, vendor management)** passes on the strength of CGI-TPR-001. Everything Projects 1 and 4 built is visible here; everything that was never built is visible too.

### 4.2 The score

| Category | Criteria | Type I readiness | Type II readiness | Criteria with adequate design |
|---|---|---|---|---|
| Security (CC1-CC9) | 33 | 56.1% | 37.4% | 8 |
| Availability (A1) | 3 | 33.3% | 22.2% | 0 |
| Confidentiality (C1) | 2 | 50.0% | 33.3% | 0 |
| **All criteria** | **38** | **53.9%** | **36.0%** | **8** |

| Component | Calculation | Result |
|---|---|---|
| Sum of CRL capped at 2 (design) | 41 of a possible 76 | |
| **Type I readiness** | 41 ÷ 76 | **53.9% — Not ready** |
| Sum of CRL (operating) | 41 of a possible 114 | |
| **Type II readiness** | 41 ÷ 114 | **36.0% — Not ready** |
| Criteria with adequate design | 8 of 38 | |
| Criteria with operating evidence | **0 of 38** | |
| Gate failures | 6 of 8 | **Gate override applies** |

## 4.3 Go / no-go

### Type I — NO-GO

A Type I asks whether controls were **suitably designed and implemented as of a date**. The word that decides it is *implemented*: a written policy is not an implemented control. Forty-three of the 88 applicable Annex A controls are Not started, which is why 30 of 38 criteria carry at least one design hole and readiness sits at 53.9%.

The failure is not evenly spread, and that is useful. **CC8.1 has a mean of 0.00 across ten mapped controls. CC6.6 and CC6.8 are at 0. CC1.2 has no oversight body to test. CC2.3 has communicated nothing to anybody.** A Type I examination commissioned today would produce a qualified or adverse opinion, and the report would be worse than having none — it would put the gaps in writing, in a document the customer keeps.

### Type II — NO-GO, and it is not a question of percentage

A Type II asks whether controls **operated effectively throughout a period**. Operating effectiveness is tested by drawing a sample from a population of real occurrences. The Statement of Applicability records **zero controls implemented**, so for most criteria **the population is zero**, and the audit in Part 5 confirms it: no restore test, no privileged access review, no scheduled vendor review, no change record, no incident, no management review, no internal audit.

> **You cannot sample nothing.** The Type II percentage of 36.0% overstates the position, because a single criterion at CRL 3 would be worth more than the twenty-three at CRL 1 put together.

## 4.4 Type I or Type II — the recommendation

**Do neither yet. Do ISO/IEC 27001 first, then a Type I, then a Type II.**

| Option | Verdict |
|---|---|
| Type I now | No. Qualified or adverse opinion; permanent written record of the gaps |
| Type II now | No. Zero populations; the engagement would be abandoned in fieldwork |
| **Type I as of 31 March 2028** | **Recommended.** After the ISO certificate (Nov 2027), the ISO evidence machine is running and the design gaps are closed |
| **Type II covering 1 April – 30 September 2028** | **Recommended.** Six months is the market norm for a first report; issue ~November 2028 |
| Aggressive: Type I as of 31 October 2027, Type II 1 Nov 2027 – 30 Apr 2028 | Possible **only** if REC-06, REC-07 and REC-11 all land on time and SOC-07 (evidence capture) starts in Q1 2027. Reserve it for a named enterprise deal that requires SOC 2 |

**Why ISO first.** The two frameworks want the same controls, and ISO additionally forces the machine that produces evidence: objectives, monitoring, internal audit, management review, corrective action. Running ISO first means the SOC 2 observation period begins with populations that already exist. Running SOC 2 first would mean building the same controls without the machine, and then building the machine anyway.

**Why not simply wait.** Because the commercial question does not wait. The honest answer to a buyer asking for a SOC 2 today is a trust page carrying the ISO roadmap with dates, this readiness assessment, the CUEC schedule, and a named date for the Type II — action **SOC-13**. "We are working on it" is not an answer. "Type I as of 31 March 2028, Type II period closing 30 September 2028, here is the readiness assessment and the gap list" is.

### 4.5 The observation period, and how it lines up with ISO

| Date | Event | Source |
|---|---|---|
| Oct–Dec 2026 | ISO foundation: scope, ISMS policy, risk acceptance criteria, SoA approval, six DPAs | ISO-01 to ISO-09 |
| Q1 2027 | **REC-06 secure development** and **REC-07 logging and alerting** — the two immovable dates | CGI-GAP-001 |
| Q1 2027 | **SOC-07 evidence capture** stands up so populations start accumulating | This document |
| May 2027 | **ISO-12 independent internal audit**, combined with the SOC 2 readiness re-assessment (conflict SC-07) | ISO-12 |
| Jun 2027 | Management review #2 | ISO-13 |
| Jul 2027 | ISO Stage 1 | ISO-17 |
| Sep 2027 | First Tier 1 vendor re-reviews — the supplier cycle fires for the first time | CGI-TPR-001 |
| **Oct 2027** | **ISO Stage 2** | ISO-17 |
| Nov 2027 | ISO certificate | ISO-17 |
| Nov–Dec 2027 | SOC-08 select the CPA firm; SOC-09 readiness re-run; SOC-13 trust page | This document |
| **31 Mar 2028** | **SOC 2 Type I as of this date** | SOC-10 |
| **1 Apr – 30 Sep 2028** | **Type II observation period** | SOC-11 |
| Nov 2028 | Type II report issued | SOC-12 |

The six months between the ISO certificate and the Type I date are not slack. They are the minimum time in which the controls that ISO forced into existence accumulate enough occurrences to be worth sampling — four quarterly access reviews, two restore tests, a year of change records and a completed vendor review cycle.

---

## Part 5 — Internal audit CGI-IAU-001

### 5.1 Audit programme and plan

| Field | Value |
|---|---|
| Audit ID | **CGI-IAU-001** |
| Purpose | The internal audit required by ISO/IEC 27001 clause 9.2, simulated as a dry run of action **ISO-12** (May 2027) |
| Audit criteria | ISO/IEC 27001:2022 incl. Amd 1:2024 **clauses 4 to 10**; the **88 applicable Annex A controls** per CGI-ISO-001; **CGI-POL-001 to -005** as the organisation's own requirements (clause 9.2.1 a) |
| Scope | The whole ISMS as scoped in CGI-ISO-001 section 2: all fifty employees, all six functions, the CloudCo production environment, the source path, the identity layer and the seventeen vendor interfaces |
| Out of scope | The internal controls of the seventeen vendors; CloudCo's own controls (carved out, assured through A.5.23) |
| Period covered | The ISMS from its creation on 7 September 2026 to 25 September 2026 |
| Fieldwork | 21–25 September 2026 (simulated) |
| Auditor | O.S |
| **Independence** | **IMPAIRED AND DECLARED.** The auditor prepared CGI-ISO-001, including the SoA tested in WP-06. Affected workpapers: **WP-06** and **WP-13**. Compensating measure: the CEO reviews those two conclusions. Recommendation: ISO-12 is performed in May 2027 by an auditor independent of the preparer — this is finding **OFI-08** |

| Field | Value |
|---|---|
| Reported to | Jerry Gold, Chief Executive Officer. There is no management review to report into, which is itself finding NC-07 |
| Audit programme | This audit is the first entry. A programme covering frequency, methods, responsibilities, criteria, scope and reporting does not exist — finding **NC-06** |

### 5.1.1 The dating rule, stated before any finding is graded

The ISMS was created in September 2026 and the risk treatment plan dates most controls into 2027. Grading every Not-started control as a nonconformity would be wrong; grading none of them would be worse. The rule applied throughout:

| Situation | Grading |
|---|---|
| A clause 4–10 requirement is unmet | **Nonconformity now.** Clauses are not dated by a plan; they are due because the organisation claims to run an ISMS |
| An Annex A control's SoA target date has **passed** and it is not implemented | **Nonconformity** |
| An Annex A control's SoA target date has **not** passed | **OFI**, stating the date on which it becomes a nonconformity |
| A control failure also breaches a **present-tense legal or contractual obligation** | **Nonconformity now**, whatever the plan says |

At the audit date of 25 September 2026 **no SoA target date has passed** — the earliest is 31 October 2026. That is why nine of the ten control-related findings are OFIs, and why the one exception, **NC-09 (six vendors with no data processing agreement)**, is graded major: GDPR Article 28(3) requires the agreement *before* processing begins, and the processing is already happening.

### 5.1.2 Sampling approach

Populations were constructed from the sources named in each workpaper and tested for completeness before selection. Where a population is below about 25 it was tested in full. Random selections use a documented seed, **20260925**, so any reviewer can reproduce them; the WP-06 selection is published in `data/06-wp06-soa-sample.csv`. Where a population is zero, **no sample was drawn and no operating conclusion was reached** — the workpaper records "not performed, population zero" and tests design alone.

## 5.2 Workpaper summary

| WP | Area | Population | Sample | Design | Operating effectiveness | Findings |
|---|---|---|---|---|---|---|
| **WP-01** | Clause 4.1-4.2 Context and interested parties | 1 - the organisation's context determination | 1 (100%) | FAIL | Not performed | NC-10 |
| **WP-02** | Clause 4.3-4.4 Scope and the ISMS | 1 - the ISMS scope statement | 1 (100%) | PARTIAL | FAIL | NC-11; NC-18 |
| **WP-03** | Clause 5.1-5.3 Leadership, policy and roles | 6 documents expected (5 topic policies + 1 ISMS policy); 1 role assignment | 6 (100%) | FAIL | PARTIAL | NC-01; NC-12; NC-13 |
| **WP-04** | Clause 6.1.1 and 6.3 ISMS risks, opportunities and change planning | 0 - no records exist | 0 | FAIL | Not performed | NC-14 |
| **WP-05** | Clause 6.1.2 Risk assessment process | 2 risk acceptances in force (ACC-001, ACC-V01); 1 documented method | 2 acceptances (100%) + 1 method (100%) | PARTIAL | FAIL | NC-02; OFI-11 |

| WP | Area | Population | Sample | Design | Operating effectiveness | Findings |
|---|---|---|---|---|---|---|
| **WP-06** | Clause 6.1.3 Risk treatment and the Statement of Applicability | 93 SoA rows (88 applicable, 5 excluded); 3 residual High risks | 15 of 88 applicable rows, stratified random (seed 20260925); 5 exclusions (100%); 3 High residual risks (100%) | PASS | FAIL | NC-03 |
| **WP-07** | Clause 6.2 Information security objectives | 0 objectives; 14 KRIs exist and were tested for objective characteristics | 14 KRIs (100%) | FAIL | Not performed | NC-04 |
| **WP-08** | Clause 7.1-7.2 Resources and competence | 6 named ISMS-relevant roles (CGI-ISO-001 role cast) | 6 (100%) | FAIL | Not performed | NC-05; NC-12 |
| **WP-09** | Clause 7.3 and A.6.3 Awareness and training | 50 employees | Intended 10 (random, seed 20260925). Actual 5 - the population record does not support a larger draw | PARTIAL | FAIL | NC-15; OFI-04; OFI-06 |
| **WP-10** | Clause 7.4-7.5 Communication and documented information | 27 mandatory documented-information items | 27 (100%) | PARTIAL | FAIL | NC-16; NC-19 |
| **WP-11** | Clause 8.1-8.3 Operational planning, risk assessment and treatment performance | 2 risk assessment runs; 10 treatment actions TP-01 to TP-10; 17 externally provided services | 2 assessment runs (100%); 10 treatment actions (100%); 5 of 17 vendors (Tier 1 judgemental) | PASS for 8.2 | PASS for 8.2 | OFI-13 |
| **WP-12** | Clause 9.1 Monitoring, measurement, analysis and evaluation | 14 KRIs | 14 (100%) | PARTIAL | FAIL | NC-17 |
| **WP-13** | Clause 9.2 Internal audit, and A.5.35 independent review | 0 internal audits before this engagement; 0 audit programmes | 0 | FAIL | FAIL | NC-06; OFI-08 |
| **WP-14** | Clause 9.3 Management review | 0 management reviews | 0 | FAIL | Not performed | NC-07 |
| **WP-15** | Clause 10.1-10.2 Improvement, nonconformity and corrective action | 3 policy exceptions (EXC-001 to EXC-003); 0 nonconformity records | 3 exceptions (100%) | FAIL | FAIL | NC-08; NC-18 |

| WP | Area | Population | Sample | Design | Operating effectiveness | Findings |
|---|---|---|---|---|---|---|
| **WP-16** | A.5.1, A.5.4, A.5.36, A.5.37 Policy framework and compliance | 5 approved policies; 0 compliance checks; 0 documented operating procedures | 5 policies (100%) | PASS for approval and ownership; FAIL for compliance checking and operating procedures. | FAIL | NC-15; OFI-14 |
| **WP-17** | A.5.15-A.5.18, A.6.5, A.8.2, A.8.5 Access control lifecycle | Joiners, movers and leavers in the 12 months to 25 Sep 2026: NOT DETERMINABLE. Quarterly privileged access reviews: 0. M… | 5 staff records (100% of the records that exist); 0 privileged reviews; 50 staff for MFA enrolment (100%, in aggregate only) | PARTIAL | NOT PERFORMED for joiners/movers/leavers | OFI-06; OFI-15 |
| **WP-18** | A.5.19-A.5.23 Supplier relationships and cloud services | 17 vendors (Tier 1 = 7, Tier 2 = 6, Tier 3 = 4); 3 completed assessments; 0 scheduled reviews performed | 11 of 17: all 7 Tier 1 (100%), 3 of 6 Tier 2 (random, seed 20260925), 1 of 4 Tier 3 (random) | PASS | FAIL | OFI-07; OFI-09 |
| **WP-19** | A.5.20, A.5.34 Data processing agreements and protection of PII | 17 vendors | 17 (100%) - population below 25, tested in full | PARTIAL | FAIL | NC-09 |
| **WP-20** | A.5.24-A.5.28, A.6.8 Incident management | 0 incidents recorded in the period; 0 exercises; 0 lessons-learned records | 0 incidents; 1 plan (100%) | PASS with exceptions | NOT PERFORMED | OFI-16 |
| **WP-21** | A.5.29, A.5.30, A.8.13 Continuity and backup (CG-01) | Restore tests performed in the period: 0. Declared RTO/RPO values: 0. | 0 restore tests; 1 backup configuration (100%) | FAIL | NOT PERFORMED | OFI-01 |
| **WP-22** | A.8.3, A.8.4, A.8.8, A.8.19, A.8.25, A.8.26, A.8.28, A.8.29, A.8.31, A.8.32 Secure development (CG-02, R-004) | Production releases in the 12 months to 25 Sep 2026: NOT DETERMINABLE. Peer-reviewed merges: NOT DETERMINABLE. Vulnerabi… | 0 - no testable population | FAIL | NOT PERFORMED | OFI-02; OFI-17 |
| **WP-23** | A.8.9, A.8.15, A.8.16, A.8.20-A.8.22 Cloud configuration, logging and monitoring (CG-03, R-005) | Configuration baselines: 0. Drift detection reports: 0. Security alerts raised and handled: 0. Log sources under retenti… | 0 baselines; 4 CloudCo CUECs (100%) | FAIL | FAIL on the CUECs: 0 of 4 accepted and assigned. NOT PERFORMED elsewhere | OFI-03; OFI-07 |
| **WP-24** | A.5.9, A.5.12, A.5.13, A.8.1, A.8.10-A.8.12 Asset, classification and data protection (CG-05) | Asset inventory entries: 0 (a 17-row vendor inventory exists and is not an asset inventory). Endpoints registered: 0 of … | 17 vendor rows (100%, as an input only); 4 classification tiers (100%) | PARTIAL | FAIL | OFI-05; OFI-18 |

## 5.3 Workpapers in full

### WP-01 — Clause 4.1-4.2 Context and interested parties

| Field | Value |
|---|---|
| **Objective** | Determine whether internal and external issues and interested parties' requirements have been determined and are documented. |
| **Audit criteria** | ISO/IEC 27001:2022 clauses 4.1, 4.2 (incl. Amd 1:2024 climate-change consideration) |
| **Population** | 1 - the organisation's context determination |
| **Population source and completeness** | Single occurrence; no sampling applicable |
| **Sample size** | 1 (100%) |
| **Selection method** | Inspection of documented information; inquiry of the CEO |
| **Test steps** | 1. Request the documented context and issues statement. 2. Inspect for internal and external issues. 3. Inspect for the climate-change relevance decision required by Amd 1:2024. 4. Request the interested-parties register and the decision on which requirements the ISMS addresses. |
| **Evidence inspected** | CGI-RSK-001 v1.1 assumptions A-01 to A-06; CGI-POL-005 s5.6.3 (GDPR duty); CGI-TPR-001 vendor inventory |
| **Test of design** | FAIL - no documented context statement exists; context survives only as six risk-register assumptions. |
| **Test of operating effectiveness** | Not performed - design failed. |
| **Conclusion** | Context and interested parties are not documented. The climate-change relevance decision has never been made. |
| **Findings raised** | NC-10 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-02 — Clause 4.3-4.4 Scope and the ISMS

| Field | Value |
|---|---|
| **Objective** | Determine whether the ISMS scope is documented and approved, and whether the ISMS operates as one system. |
| **Audit criteria** | Clauses 4.3, 4.4 |
| **Population** | 1 - the ISMS scope statement |
| **Population source and completeness** | Single occurrence; no sampling applicable |
| **Sample size** | 1 (100%) |
| **Selection method** | Inspection; inquiry of the CEO and CTO |
| **Test steps** | 1. Obtain the scope statement. 2. Verify interfaces and dependencies are considered (4.3 c). 3. Verify top-management approval. 4. Request an ISMS process map linking clauses 4-10. |
| **Evidence inspected** | CGI-ISO-001 s2.1 scope wording (draft); s2.2 boundary table; 17 vendor interfaces |
| **Test of design** | PARTIAL - the scope text is complete and names interfaces, but it is a draft. |
| **Test of operating effectiveness** | FAIL - no approval record exists; no ISMS process map exists. |
| **Conclusion** | Scope is drafted to an auditable standard but has not been approved by top management. The ISMS components (policies, register, gap assessment, vendor programme, SoA) do not yet operate as one system. |
| **Findings raised** | NC-11; NC-18 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-03 — Clause 5.1-5.3 Leadership, policy and roles

| Field | Value |
|---|---|
| **Objective** | Determine whether top management demonstrates leadership, whether an information security policy meeting 5.2 a)-d) exists, and whether ISMS roles are assigned. |
| **Audit criteria** | Clauses 5.1, 5.2, 5.3 |
| **Population** | 6 documents expected (5 topic policies + 1 ISMS policy); 1 role assignment |
| **Population source and completeness** | CGI document register (does not exist); enumerated from CGI-POL-001 to -005 |
| **Sample size** | 6 (100%) |
| **Selection method** | Inspection of approval blocks; inquiry of the CEO |
| **Test steps** | 1. Inspect each policy's approval record and approver. 2. Test for a top-level ISMS policy meeting 5.2 a) to d). 3. Request the approved ISMS budget. 4. Request the written assignment of ISMS conformance and reporting responsibility. |
| **Evidence inspected** | CGI-POL-001 to -005 v1.0 approval blocks (CGI-POL-002 approver corrected to the CEO); CGI-RSK-001 year-one budget USD 32,100 (unapproved) |
| **Test of design** | FAIL - no ISMS-level policy exists. Five topic-specific policies do not together meet 5.2 a) to d). |
| **Test of operating effectiveness** | PARTIAL - approval of the five topic policies is evidenced; budget approval and role assignment are not. |
| **Conclusion** | No information security policy exists at ISMS level. The USD 32,100 budget is costed but unapproved. Nobody is assigned responsibility for ISMS conformance or for reporting its performance to top management. |
| **Findings raised** | NC-01; NC-12; NC-13 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-04 — Clause 6.1.1 and 6.3 ISMS risks, opportunities and change planning

| Field | Value |
|---|---|
| **Objective** | Determine whether risks and opportunities for the ISMS itself have been determined and whether ISMS changes are planned. |
| **Audit criteria** | Clauses 6.1.1, 6.3 |
| **Population** | 0 - no records exist |
| **Population source and completeness** | Confirmed by inquiry and by absence from the CGI document set |
| **Sample size** | 0 |
| **Selection method** | Inquiry; search of the document set |
| **Test steps** | 1. Request the ISMS risks and opportunities record. 2. Request evidence of planned ISMS changes. |
| **Evidence inspected** | None. CGI-RSK-001 addresses information security risks, which are a different object from ISMS risks and opportunities. |
| **Test of design** | FAIL - requirement absent. |
| **Test of operating effectiveness** | Not performed - population zero. |
| **Conclusion** | Neither requirement has ever been addressed. The register's 14 risks are information security risks, not ISMS risks and opportunities. |
| **Findings raised** | NC-14 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-05 — Clause 6.1.2 Risk assessment process

| Field | Value |
|---|---|
| **Objective** | Determine whether a documented risk assessment process exists, including risk acceptance criteria and criteria for performing assessments. |
| **Audit criteria** | Clause 6.1.2 a)-e) |
| **Population** | 2 risk acceptances in force (ACC-001, ACC-V01); 1 documented method |
| **Population source and completeness** | CGI-RSK-001 v1.1 s4; CGI-TPR-001 s5.3 |
| **Sample size** | 2 acceptances (100%) + 1 method (100%) |
| **Selection method** | Inspection; re-performance of two register scorings |
| **Test steps** | 1. Inspect the documented method (NIST SP 800-30 Rev. 1 5x5, thresholds). 2. Test for risk acceptance criteria. 3. Trace ACC-001 and ACC-V01 to the criteria they were accepted against. 4. Re-perform the scoring of two risks. 5. Test whether fraud was considered (informs the SOC 2 overlay, CC3.3). |
| **Evidence inspected** | CGI-RSK-001 v1.1 methodology and thresholds (Low 1-4 / Medium 5-9 / High 10-14 / Critical 15-25); ACC-001 (SMS MFA, expires 03 Mar 2027); ACC-V01 (SchedulerCo, expires 15 Sep 2028) |
| **Test of design** | PARTIAL - the assessment and analysis method is documented and consistently applied. Acceptance criteria are absent. |
| **Test of operating effectiveness** | FAIL - both acceptances in force were made against criteria that do not exist. Re-performance of two scorings agreed to the register. |
| **Conclusion** | The method is sound and has operated twice (v1.0 and v1.1). No risk acceptance criteria exist, so neither acceptance in force can be shown to be within appetite. Fraud has never been considered as a risk category. |
| **Findings raised** | NC-02; OFI-11 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-06 — Clause 6.1.3 Risk treatment and the Statement of Applicability

| Field | Value |
|---|---|
| **Objective** | Determine whether controls are determined by risk, compared with Annex A, recorded in an approved SoA, and whether residual risks are accepted by risk owners. |
| **Audit criteria** | Clause 6.1.3 a)-f); SoA per 6.1.3 d) |
| **Population** | 93 SoA rows (88 applicable, 5 excluded); 3 residual High risks |
| **Population source and completeness** | CGI-ISO-001 s3.8, complete and reconciled to 93 in Appendix A |
| **Sample size** | 15 of 88 applicable rows, stratified random (seed 20260925); 5 exclusions (100%); 3 High residual risks (100%) |
| **Selection method** | Attribute testing by inspection and re-performance; stratified random selection with a documented seed |
| **Test steps** | 1. Select 15 applicable rows stratified across A.5/A.6/A.7/A.8. 2. For each, trace risk ID -> control -> stated evidence and agree the status to the evidence. 3. Test all 5 exclusions for a justification that names what would reverse it. 4. Test for CEO approval of the SoA. 5. Test for risk-owner acceptance of R-004, R-005 and VR-004. |
| **Evidence inspected** | CGI-ISO-001 SoA v1.0 (draft); CGI-RSK-001 v1.1; CGI-TPR-001 findings F-001 to F-013 |
| **Test of design** | PASS - traceability holds on all 15 sampled rows; all 5 exclusions name a reversing condition. |
| **Test of operating effectiveness** | FAIL - the SoA is unapproved and no residual-risk acceptance exists for the three High residual risks. |
| **Conclusion** | The SoA is complete, traceable and honest (0 Implemented, 45 Partial, 43 Not started). It has not been approved, no consolidated risk treatment plan exists, and the risk owners have not accepted the residual risk on R-004, R-005 or VR-004. |
| **Findings raised** | NC-03 |

| Field | Value |
|---|---|
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-07 — Clause 6.2 Information security objectives

| Field | Value |
|---|---|
| **Objective** | Determine whether measurable information security objectives are established, monitored and communicated. |
| **Audit criteria** | Clause 6.2 a)-j) |
| **Population** | 0 objectives; 14 KRIs exist and were tested for objective characteristics |
| **Population source and completeness** | CGI-RSK-001 v1.1 KRI schedule |
| **Sample size** | 14 KRIs (100%) |
| **Selection method** | Inspection against the 6.2 characteristics |
| **Test steps** | 1. Request documented objectives. 2. Test each of the 14 KRIs against 6.2 a) to j): measurable, monitored, communicated, with a plan, resources, responsibility, timescale and evaluation. |
| **Evidence inspected** | CGI-RSK-001 v1.1 KRI-01 to KRI-07 and KRI-V1 to KRI-V7 |
| **Test of design** | FAIL - no objectives exist. None of the 14 KRIs carries a target, an owner, a timescale or an evaluation method, so none is an objective. |
| **Test of operating effectiveness** | Not performed - population zero. |
| **Conclusion** | Indicators have been mistaken for objectives. An indicator reports a number; an objective states the number you intend to reach, by when and who owns it. |
| **Findings raised** | NC-04 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-08 — Clause 7.1-7.2 Resources and competence

| Field | Value |
|---|---|
| **Objective** | Determine whether resources are provided and whether competence is determined, achieved and evidenced. |
| **Audit criteria** | Clauses 7.1, 7.2 a)-d) |
| **Population** | 6 named ISMS-relevant roles (CGI-ISO-001 role cast) |
| **Population source and completeness** | CGI-ISO-001 s2.2 and the simulated role cast |
| **Sample size** | 6 (100%) |
| **Selection method** | Inquiry; inspection of personnel records |
| **Test steps** | 1. Request the approved ISMS budget and time allocation. 2. For each role, request the competence requirement and the evidence of competence (qualification, training or experience record). |
| **Evidence inspected** | None on file for competence. Budget estimated in CGI-RSK-001 but unapproved. |
| **Test of design** | FAIL - no competence requirements exist for any ISMS role. |
| **Test of operating effectiveness** | Not performed - design failed. |
| **Conclusion** | No competence requirements and no documented evidence of competence exist for any role. Clause 7.2 d) requires the evidence to be retained. |
| **Findings raised** | NC-05; NC-12 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-09 — Clause 7.3 and A.6.3 Awareness and training

| Field | Value |
|---|---|
| **Objective** | Determine whether all persons doing work under the organisation's control are aware of the policy, their contribution and the implications of non-conformance. |
| **Audit criteria** | Clause 7.3 a)-c); A.6.3 |
| **Population** | 50 employees |
| **Population source and completeness** | Company headcount per the scenario baseline; CGI-TRK-001 holds a five-person illustrative sample only |
| **Sample size** | Intended 10 (random, seed 20260925). Actual 5 - the population record does not support a larger draw |
| **Selection method** | Attribute testing; random selection; inspection of acknowledgement records |
| **Test steps** | 1. Obtain the acknowledgement population from CGI-TRK-001. 2. Test completeness and accuracy of that population against the HR system of record. 3. Select 10 at random. 4. Inspect each acknowledgement date and the training record behind it. |
| **Evidence inspected** | CGI-TRK-001: 60% acknowledged (30 of 50), 80% MFA enrolled (40 of 50); five-person illustrative sample; CGI-POL-003 s4.3.6 induction |
| **Test of design** | PARTIAL - induction awareness is designed. No recurring or role-based curriculum exists (CG-04). |
| **Test of operating effectiveness** | FAIL - 20 of 50 staff have not acknowledged the policy pack. The tracker holds per-person detail for five people only, so the population could not be tested for completeness. |
| **Conclusion** | 40% of staff are bound by rules they have not acknowledged. The acknowledgement population is itself unverifiable, which is an information-produced-by-the-entity limitation recorded separately. |
| **Findings raised** | NC-15; OFI-04; OFI-06 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-10 — Clause 7.4-7.5 Communication and documented information

| Field | Value |
|---|---|
| **Objective** | Determine whether ISMS communication is planned and whether documented information is controlled. |
| **Audit criteria** | Clauses 7.4, 7.5.1-7.5.3 |
| **Population** | 27 mandatory documented-information items |
| **Population source and completeness** | CGI-ISO-001 Part 5 checklist DI-01 to DI-27 |
| **Sample size** | 27 (100%) |
| **Selection method** | Inspection against the control requirements of 7.5.3 |
| **Test steps** | 1. Request the ISMS communication plan. 2. For each of the 27 items, test availability, version control, approval and retention. 3. Request the document and record control procedure and the document register. |
| **Evidence inspected** | CGI-POL-001 to -005 document control blocks (version, owner, review date); CGI-ISO-001 Part 5 |
| **Test of design** | PARTIAL - individual documents carry control blocks. There is no procedure and no register above them. |
| **Test of operating effectiveness** | FAIL - 4 Have, 11 Partial, 12 Missing of 27. No communication plan exists. |
| **Conclusion** | Document control exists per document but not as a system. No ISMS communication plan defines what is communicated, when, to whom or how. |
| **Findings raised** | NC-16; NC-19 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-11 — Clause 8.1-8.3 Operational planning, risk assessment and treatment performance

| Field | Value |
|---|---|
| **Objective** | Determine whether processes are planned and controlled, whether risk assessments are performed and retained, and whether the risk treatment plan is implemented. |
| **Audit criteria** | Clauses 8.1, 8.2, 8.3 |
| **Population** | 2 risk assessment runs; 10 treatment actions TP-01 to TP-10; 17 externally provided services |
| **Population source and completeness** | CGI-RSK-001 v1.0 and v1.1; CGI-RSK-001 s5 treatment plan; CGI-TPR-001 inventory |
| **Sample size** | 2 assessment runs (100%); 10 treatment actions (100%); 5 of 17 vendors (Tier 1 judgemental) |
| **Selection method** | Inspection; re-performance of the aggregate risk arithmetic |
| **Test steps** | 1. Inspect both assessment runs for retained results. 2. Re-perform the v1.1 aggregate arithmetic (213 inherent, 122 residual, 43% reduction, mean 8.71). 3. Test each TP action for status and evidence. 4. Test control of externally provided processes against CGI-TPR-001 Gates A-C. |
| **Evidence inspected** | CGI-RSK-001 v1.0 (5 risks) and v1.1 (14 risks); CGI-TPR-001 workflow; CG-06 closed |
| **Test of design** | PASS for 8.2 - the process is defined and has been performed on schedule and on change. |
| **Test of operating effectiveness** | PASS for 8.2 - results retained and arithmetic re-performed without exception. PARTIAL for 8.1 and 8.3 - Wave 1 treatment actions are not yet due. |
| **Conclusion** | Clause 8.2 is the only requirement in clauses 4-10 fully met. Treatment actions are dated but not yet due at the audit date, so their non-completion is not a nonconformity. |
| **Findings raised** | OFI-13 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-12 — Clause 9.1 Monitoring, measurement, analysis and evaluation

| Field | Value |
|---|---|
| **Objective** | Determine what is monitored and measured, by what methods, when, by whom, and whether results are analysed, evaluated and retained. |
| **Audit criteria** | Clause 9.1 a)-f) |
| **Population** | 14 KRIs |
| **Population source and completeness** | CGI-RSK-001 v1.1 (7 original + 7 vendor KRIs) |
| **Sample size** | 14 (100%) |
| **Selection method** | Inspection; inquiry of the CTO |
| **Test steps** | 1. For each KRI, test whether it has been measured, when, by whom and where the result is retained. 2. Request the monitoring programme and the reporting route. |
| **Evidence inspected** | KRI-V1 measured once at 65% (6 of 17 vendors without a DPA). No other KRI has ever been measured. |
| **Test of design** | PARTIAL - indicators are defined with thresholds. |
| **Test of operating effectiveness** | FAIL - 1 of 14 measured once; 13 never measured; no results reported to anybody. |
| **Conclusion** | Measurement has occurred once, as a by-product of the vendor programme, and has never been reported. There is no monitoring programme and no analysis or evaluation step. |
| **Findings raised** | NC-17 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-13 — Clause 9.2 Internal audit, and A.5.35 independent review

| Field | Value |
|---|---|
| **Objective** | Determine whether an internal audit programme exists and whether internal audits are conducted at planned intervals by objective and impartial auditors. |
| **Audit criteria** | Clauses 9.2.1, 9.2.2; A.5.35 |
| **Population** | 0 internal audits before this engagement; 0 audit programmes |
| **Population source and completeness** | Inquiry of the CEO; absence from the document set |
| **Sample size** | 0 |
| **Selection method** | Inquiry; search of the document set; self-assessment of this engagement's independence |
| **Test steps** | 1. Request the audit programme (frequency, methods, responsibilities, criteria, scope, reporting). 2. Request prior audit reports. 3. Assess the independence of the present engagement against 9.2.2 c). |
| **Evidence inspected** | None. This engagement, CGI-IAU-001, is the first. |
| **Test of design** | FAIL - no audit programme exists. |
| **Test of operating effectiveness** | FAIL - no audit had ever been performed. This engagement does not close the requirement because the auditor prepared CGI-ISO-001 and is therefore auditing their own work. |
| **Conclusion** | Clause 9.2 is wholly unmet. This dry run gives the organisation the method and the workpapers, not the conformity: the same person prepared the Statement of Applicability under test. |
| **Findings raised** | NC-06; OFI-08 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-14 — Clause 9.3 Management review

| Field | Value |
|---|---|
| **Objective** | Determine whether top management reviews the ISMS at planned intervals, using the required inputs, with documented results. |
| **Audit criteria** | Clauses 9.3.1, 9.3.2 a)-g), 9.3.3 |
| **Population** | 0 management reviews |
| **Population source and completeness** | Inquiry of the CEO; CGI-GAP-001 GAP-005 records that no security item has reached a leadership agenda |
| **Sample size** | 0 |
| **Selection method** | Inquiry; inspection of leadership meeting records |
| **Test steps** | 1. Request minutes of any management review. 2. Test any leadership agenda for the 9.3.2 a) to g) inputs. 3. Request documented results and decisions. |
| **Evidence inspected** | None. CGI-GAP-001 REC-10 proposes a quarterly security review from Q1 2027, with an agenda that omits several 9.3.2 inputs. |
| **Test of design** | FAIL - requirement absent. |
| **Test of operating effectiveness** | Not performed - population zero. |
| **Conclusion** | No management review has ever been held. The planned REC-10 forum is not yet a clause 9.3 review: its agenda covers KRIs, the scorecard and treatment status, and omits several required inputs. |
| **Findings raised** | NC-07 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-15 — Clause 10.1-10.2 Improvement, nonconformity and corrective action

| Field | Value |
|---|---|
| **Objective** | Determine whether nonconformities are reacted to, root causes evaluated, corrective actions taken and their effectiveness reviewed, with records retained. |
| **Audit criteria** | Clauses 10.1, 10.2 a)-g) |
| **Population** | 3 policy exceptions (EXC-001 to EXC-003); 0 nonconformity records |
| **Population source and completeness** | CGI-POL-001 exception register; absence of an NC log |
| **Sample size** | 3 exceptions (100%) |
| **Selection method** | Inspection; inquiry |
| **Test steps** | 1. Request the nonconformity and corrective action log. 2. Test whether the exception register functions as one. 3. Request the improvement log. |
| **Evidence inspected** | EXC-001 to EXC-003; CGI-POL-005 s5.7 incident corrective actions (scope limited to incidents) |
| **Test of design** | FAIL - no nonconformity and corrective action process exists. |
| **Test of operating effectiveness** | FAIL - the exception register records approved deviations, not nonconformities, and carries no root-cause or effectiveness step. |
| **Conclusion** | An approved exception is a decision to depart from a rule. A nonconformity is a failure to meet a requirement. The organisation has a register for the first and none for the second. |
| **Findings raised** | NC-08; NC-18 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-16 — A.5.1, A.5.4, A.5.36, A.5.37 Policy framework and compliance

| Field | Value |
|---|---|
| **Objective** | Determine whether topic-specific policies are approved, communicated, reviewed and complied with, and whether operating procedures exist beneath them. |
| **Audit criteria** | Annex A controls A.5.1, A.5.4, A.5.36, A.5.37 |
| **Population** | 5 approved policies; 0 compliance checks; 0 documented operating procedures |
| **Population source and completeness** | CGI-POL-001 to -005; CGI-TRK-001 |
| **Sample size** | 5 policies (100%) |
| **Selection method** | Inspection of approval and review records; inquiry |
| **Test steps** | 1. Test each policy for approval, owner, version and review date. 2. Request the first annual review record. 3. Request compliance-check records against policy. 4. Request the runbooks named in the policies. |
| **Evidence inspected** | CGI-POL-001 to -005 v1.0, all approved with document control blocks; no annual review has fallen due; no runbooks exist |
| **Test of design** | PASS for approval and ownership; FAIL for compliance checking and operating procedures. |
| **Test of operating effectiveness** | FAIL - no compliance check against policy has ever been performed; no procedures exist beneath the policies. |
| **Conclusion** | The policy layer is genuinely strong and is the best-evidenced part of the ISMS. Nothing beneath it has been built, and nothing above it checks it. |
| **Findings raised** | NC-15; OFI-14 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-17 — A.5.15-A.5.18, A.6.5, A.8.2, A.8.5 Access control lifecycle

| Field | Value |
|---|---|
| **Objective** | Determine whether access is granted, reviewed and revoked in accordance with the approved policy. |
| **Audit criteria** | Annex A controls A.5.15, A.5.16, A.5.17, A.5.18, A.6.5, A.8.2, A.8.5; CGI-POL-003 s4.5.2 (four-hour revocation) and s4.7.1 (quarterly privileged review) |
| **Population** | Joiners, movers and leavers in the 12 months to 25 Sep 2026: NOT DETERMINABLE. Quarterly privileged access reviews: 0. MFA enrolment: 50 staff. |
| **Population source and completeness** | No joiner/leaver register or completed offboarding checklist archive exists. CGI-TRK-001 holds five illustrative staff records. The population could not be reconciled to an HR system of record. |
| **Sample size** | 5 staff records (100% of the records that exist); 0 privileged reviews; 50 staff for MFA enrolment (100%, in aggregate only) |
| **Selection method** | Attribute testing by inspection; population completeness testing (C&A / IPE) |
| **Test steps** | 1. Obtain the joiner/mover/leaver population and reconcile it to HR records. 2. Select leavers and test revocation against the four-hour SLA. 3. Test all quarterly privileged access reviews in the period. 4. Test MFA enrolment against the 100% requirement and against ACC-001. |
| **Evidence inspected** | CGI-POL-003 v1.0; CGI-TRK-001 (80% MFA enrolled); ACC-001 accepting SMS MFA until 03 Mar 2027; CGI-TPR-001 F-003 (no SCIM on ChatCo, manual leaver removal); one account (Lena Fischer) correctly not yet created under CGI-POL-003 s4.3.3 |
| **Test of design** | PARTIAL - CGI-POL-003 is an approved and complete access control design. It cannot be met on the four non-federated vendors (F-003). |
| **Test of operating effectiveness** | NOT PERFORMED for joiners/movers/leavers - the population could not be established. FAIL for privileged access review - zero reviews in the period against a quarterly requirement. FAIL for MFA - 10 of 50 not enrolled. |
| **Conclusion** | The most important result in this audit is a negative one: the leaver population cannot be established, so the four-hour revocation control cannot be tested at all. An untestable control is not a passing control. |
| **Findings raised** | OFI-06; OFI-15 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## WP-18 — A.5.19-A.5.23 Supplier relationships and cloud services

| Field | Value |
|---|---|
| **Objective** | Determine whether supplier security requirements are defined, agreed, monitored and reviewed on the defined cadence. |
| **Audit criteria** | Annex A controls A.5.19, A.5.20, A.5.21, A.5.22, A.5.23 |
| **Population** | 17 vendors (Tier 1 = 7, Tier 2 = 6, Tier 3 = 4); 3 completed assessments; 0 scheduled reviews performed |
| **Population source and completeness** | CGI-TPR-001 inventory CGI-VEN-001 to -017, reconciled to architecture, 12 months of finance transactions and IdP OAuth grants |
| **Sample size** | 11 of 17: all 7 Tier 1 (100%), 3 of 6 Tier 2 (random, seed 20260925), 1 of 4 Tier 3 (random) |
| **Selection method** | Attribute testing; stratified selection, census of the highest tier |
| **Test steps** | 1. Test each sampled vendor for tier, assessment, DPA, assurance artifact and review date. 2. Test the review cadence (12/18/24 months) for reviews actually performed. 3. Test the CloudCo CUEC acceptance record. 4. Test the sub-processor change feed subscription. |
| **Evidence inspected** | CGI-TPR-001 v1.0; CGI-TPR-002 (74 questions, 16 domains); VRA-2026-001 CloudCo PASS WITH CONDITIONS 89%; VRA-2026-002 ChatCo FAIL 65%; VRA-2026-003 SchedulerCo ACCEPTED 92%; findings F-001 to F-013 |
| **Test of design** | PASS - the programme is designed, owned and communicated: tiering model, questionnaire, onboarding gates, 18-clause contract checklist, review cadence. |

| Field | Value |
|---|---|
| **Test of operating effectiveness** | FAIL - zero scheduled reviews have been performed; the first Tier 1 re-reviews fall due Sep 2027. The four CloudCo CUECs are unaccepted. No sub-processor change feed is subscribed. ChatCo has operated in FAIL status since 15 Sep 2026 with no expiring risk acceptance on file. |
| **Conclusion** | Designed, not cycled. This is the clearest example in the ISMS of the difference between a control that exists and a control that operates. |
| **Findings raised** | OFI-07; OFI-09 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-19 — A.5.20, A.5.34 Data processing agreements and protection of PII

| Field | Value |
|---|---|
| **Objective** | Determine whether every vendor processing personal data on the organisation's behalf is bound by a written data processing agreement, and whether a record of processing activities exists. |
| **Audit criteria** | Annex A controls A.5.20, A.5.34; GDPR Articles 28 and 30 as a legal requirement identified under clause 4.2 |
| **Population** | 17 vendors |
| **Population source and completeness** | CGI-TPR-001 inventory; KRI-V1 measurement of 15 Sep 2026 |
| **Sample size** | 17 (100%) - population below 25, tested in full |
| **Selection method** | Attribute testing by inspection of executed agreements |
| **Test steps** | 1. For each of the 17 vendors, inspect for an executed DPA. 2. Test whether personal data is in fact processed. 3. Request the GDPR Article 30 record of processing activities. 4. Test for a transfer register covering non-EEA processing. |
| **Evidence inspected** | 11 executed DPAs; 6 vendors with none (KRI-V1 = 65%); CGI-TPR-001 F-001 (ChatCo: no DPA, US-hosted), F-004, O-001; no Article 30 record exists |
| **Test of design** | PARTIAL - CGI-TPR-001 Gate B forbids onboarding without a DPA. The gate was built after the six were onboarded. |
| **Test of operating effectiveness** | FAIL - 6 of 17 vendors, 35% of the estate, process data with no data processing agreement. |
| **Conclusion** | This is a present-tense legal non-compliance, not a future roadmap item. GDPR Article 28(3) requires the agreement to be in place before processing begins; the processing is already happening. The finding does not depend on the SoA target date of 31 October 2026. |
| **Findings raised** | NC-09 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-20 — A.5.24-A.5.28, A.6.8 Incident management

| Field | Value |
|---|---|
| **Objective** | Determine whether incident management is planned, whether events are assessed and responded to, and whether lessons are learned. |
| **Audit criteria** | Annex A controls A.5.24, A.5.25, A.5.26, A.5.27, A.5.28, A.6.8 |
| **Population** | 0 incidents recorded in the period; 0 exercises; 0 lessons-learned records |
| **Population source and completeness** | Inquiry; no incident register entries exist |
| **Sample size** | 0 incidents; 1 plan (100%) |
| **Selection method** | Inspection of the plan; walkthrough with the CTO; inquiry |
| **Test steps** | 1. Inspect CGI-POL-005 for severity bands, roles, targets and reporting channels. 2. Walk through a hypothetical SEV1 with the CTO. 3. Request incident register entries. 4. Request the tabletop exercise record and lessons learned. |

| Field | Value |
|---|---|
| **Evidence inspected** | CGI-POL-005 v1.0 with SEV1-SEV4, s5.2 reporting channels, s5.5 response stages, s5.6.3 GDPR 72-hour duty, s5.7 review; CGI-TPR-001 F-002 (no vendor breach-notification clause), F-008 (no tenant audit log on ChatCo) |
| **Test of design** | PASS with exceptions - the plan is approved and complete on severity, roles and targets. No containment runbooks exist and no out-of-band communication channel is named. |
| **Test of operating effectiveness** | NOT PERFORMED - population zero. No incident has occurred and no exercise has been run, so operating effectiveness cannot be tested. |
| **Conclusion** | Design is the strongest of any control family outside the policy pack. Zero occurrences means zero evidence: the walkthrough is all the assurance available, and inquiry plus a walkthrough is not sufficient evidence of operation. |
| **Findings raised** | OFI-16 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-21 — A.5.29, A.5.30, A.8.13 Continuity and backup (CG-01)

| Field | Value |
|---|---|
| **Objective** | Determine whether backups are performed, protected and tested, and whether ICT continuity objectives are declared. |
| **Audit criteria** | Annex A controls A.5.29, A.5.30, A.8.13; CGI-RSK-001 control gap CG-01 |
| **Population** | Restore tests performed in the period: 0. Declared RTO/RPO values: 0. |
| **Population source and completeness** | Inquiry of the IT Operations Manager; CGI-TPR-001 F-013 |
| **Sample size** | 0 restore tests; 1 backup configuration (100%) |
| **Selection method** | Inspection of configuration; inquiry; attempted re-performance |
| **Test steps** | 1. Inspect the CloudCo snapshot configuration and schedule. 2. Request declared RTO and RPO. 3. Request restore test reports for the period. 4. Request evidence that the data export path has been exercised. |
| **Evidence inspected** | CloudCo native snapshots configured (eu-central-1 primary, us-east-1 backup copies); CGI-TPR-001 F-013 (no RTO, no RPO, no restore test, export never exercised); VRA-2026-001 condition C4 due 15 Dec 2026 |
| **Test of design** | FAIL - no CGI-POL-006, no declared recovery objectives, no test schedule. A backup with no restore test and no objective is an assumption, not a control. |
| **Test of operating effectiveness** | NOT PERFORMED - population zero. |
| **Conclusion** | Backups exist and have never been proven to restore. CGI-RSK-001 correctly takes no credit for them against R-002. The SoA target date of 15 December 2026 has not passed, so this is recorded as an opportunity for improvement that becomes a nonconformity on 16 December 2026. |
| **Findings raised** | OFI-01 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-22 — A.8.3, A.8.4, A.8.8, A.8.19, A.8.25, A.8.26, A.8.28, A.8.29, A.8.31, A.8.32 Secure development (CG-02, R-004)

| Field | Value |
|---|---|
| **Objective** | Determine whether changes to the platform are authorised, reviewed, tested and separated from production, and whether vulnerabilities are identified and remediated. |
| **Audit criteria** | Ten Annex A controls on the code path; CGI-RSK-001 control gap CG-02 and risk R-004 |
| **Population** | Production releases in the 12 months to 25 Sep 2026: NOT DETERMINABLE. Peer-reviewed merges: NOT DETERMINABLE. Vulnerability scans: 0. Penetration tests: 0. |

| Field | Value |
|---|---|
| **Population source and completeness** | No change record, release log or branch-protection configuration exists, so no population can be constructed and no completeness assertion can be made. |
| **Sample size** | 0 - no testable population |
| **Selection method** | Attempted population construction; inspection of repository configuration; inquiry of the CTO |
| **Test steps** | 1. Request the change record or release log for the period. 2. Request the CodeCo branch-protection configuration export. 3. Request scan reports and remediation tickets. 4. Request the penetration test report. 5. Request the environment separation diagram. |
| **Evidence inspected** | CGI-POL-002 s4.5.2 secret scanning (a fragment); CGI-VEN-002 CodeCo Tier 1, inherent 15 Critical, no branch protection on the CGI side; CGI-GAP-001 PR.PS = 0 |
| **Test of design** | FAIL - CGI-POL-007 and CGI-POL-008 are unwritten. There is no coding standard, no mandatory peer review, no scanning SLA and no recorded environment separation. |
| **Test of operating effectiveness** | NOT PERFORMED - no population could be constructed. |
| **Conclusion** | Ten of the eleven code-path controls behind the organisation's joint-highest residual risk are Not started, and an eleventh (A.5.7 threat intelligence) is tested in WP-05. Engineers can commit directly to production with no second person. SoA target dates of 31 March 2027 have not passed, so the finding is recorded as an OFI that becomes a nonconformity on 01 April 2027. |
| **Findings raised** | OFI-02; OFI-17 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-23 — A.8.9, A.8.15, A.8.16, A.8.20-A.8.22 Cloud configuration, logging and monitoring (CG-03, R-005)

| Field | Value |
|---|---|
| **Objective** | Determine whether cloud configuration is baselined and monitored for drift, and whether logging and alerting are in place. |
| **Audit criteria** | Annex A controls A.8.9, A.8.15, A.8.16, A.8.20, A.8.21, A.8.22; control gap CG-03 and risk R-005 |
| **Population** | Configuration baselines: 0. Drift detection reports: 0. Security alerts raised and handled: 0. Log sources under retention: 0. |
| **Population source and completeness** | Inquiry of the IT Operations Manager; CGI-TPR-001 F-010; CGI-GAP-001 PR.IR = 0, DE.CM = 1 |
| **Sample size** | 0 baselines; 4 CloudCo CUECs (100%) |
| **Selection method** | Inquiry; inspection of available configuration; attribute testing of the four CUECs |
| **Test steps** | 1. Request the CloudCo configuration baseline. 2. Request drift-detection or posture reports. 3. Test each of the four CloudCo CUECs for acceptance and an assigned owner. 4. Request CloudTrail configuration with log file validation. 5. Request alert rules and handled-alert records. |
| **Evidence inspected** | VRA-2026-001 F-010: four unaccepted CUECs (organisation-wide CloudTrail with log file validation; MFA on the root account with restricted root use; least-privilege IAM with periodic review; encryption management for customer-controlled data); MonitorCo APM used for engineering, not as a security log source |
| **Test of design** | FAIL - no baseline, no drift detection, no alert rules and no central security log account exist. |
| **Test of operating effectiveness** | FAIL on the CUECs: 0 of 4 accepted and assigned. NOT PERFORMED elsewhere - population zero. |
| **Conclusion** | R-005 stays High for exactly this reason: the gap sits on the organisation's side of the shared-responsibility boundary, where no provider certificate reaches. Condition C1 is due 15 December 2026; if it is not met, the CloudCo conditional pass lapses to Fail. |
| **Findings raised** | OFI-03; OFI-07 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

### WP-24 — A.5.9, A.5.12, A.5.13, A.8.1, A.8.10-A.8.12 Asset, classification and data protection (CG-05)

| Field | Value |
|---|---|
| **Objective** | Determine whether information and assets are inventoried, classified, labelled, retained and protected against leakage. |
| **Audit criteria** | Annex A controls A.5.9, A.5.12, A.5.13, A.8.1, A.8.10, A.8.11, A.8.12 |
| **Population** | Asset inventory entries: 0 (a 17-row vendor inventory exists and is not an asset inventory). Endpoints registered: 0 of 50. Deletion certificates: 0. DLP alerts: 0. |
| **Population source and completeness** | CGI-TPR-001 vendor inventory; CGI-GAP-001 ID.AM = 1 |
| **Sample size** | 17 vendor rows (100%, as an input only); 4 classification tiers (100%) |
| **Selection method** | Inspection; inquiry; attempted reconciliation of assets to classification |
| **Test steps** | 1. Request the asset and SaaS inventory. 2. Test whether the four CGI-POL-004 tiers have been applied to any asset. 3. Request the endpoint register for the 50 BYOD devices. 4. Request retention/deletion records and DLP alert samples. |
| **Evidence inspected** | CGI-POL-004 v1.0 four tiers and Handling Matrix (approved, never applied); EXC-003 (Restricted data on removable media); CGI-VEN-007 MonitorCo log scrubbing rules unverified |
| **Test of design** | PARTIAL - the classification scheme and handling matrix are approved and complete. No inventory exists for them to be applied to, and no DLP capability is designed. |
| **Test of operating effectiveness** | FAIL - the scheme has been applied to zero assets. No endpoint register exists for a 50-device BYOD estate. |
| **Conclusion** | A classification scheme with nothing classified is a document, not a control. The vendor inventory delivered by CGI-TPR-001 is an input to the asset inventory and is frequently mistaken for it. |
| **Findings raised** | OFI-05; OFI-18 |
| **Prepared by / date** | O.S / 25 September 2026 |
| **Reviewed by** | Jerry Gold, Chief Executive Officer — see OFI-08 independence limitation |

## 5.4 Findings register

**37 findings: 9 major nonconformities, 10 minor nonconformities, 18 opportunities for improvement.** Management responses were written by the named owners; the auditor does not write management's response.

### Major nonconformities (9)

| ID | Clause or control | Finding | Workpaper | Owner | Management response | Due |
|---|---|---|---|---|---|---|
| **NC-01** | Clause 5.2 | **No information security policy at ISMS level.** Five approved topic-specific policies (CGI-POL-001 to -005) do not together satisfy clause 5.2 a) to d): none is appropriate to the purpose of the ISMS as a whole, provides a framework for setting objectives, or commits to continual improvement of the ISMS. | WP-03 | Chief Executive Officer | Issue ISMS policy v1.0 meeting 5.2 a) to d); communicate and record acknowledgement. | 2026-10-31 |
| **NC-02** | Clause 6.1.2 a) | **No risk acceptance criteria.** The risk assessment method is documented and has operated twice, but no risk acceptance criteria or appetite exist. ACC-001 and ACC-V01 are in force and were therefore accepted against nothing. | WP-05 | Chief Executive Officer | Approve risk acceptance criteria and appetite; re-ratify ACC-001 and ACC-V01 against them. | 2026-10-31 |

| ID | Clause or control | Finding | Workpaper | Owner | Management response | Due |
|---|---|---|---|---|---|---|
| **NC-03** | Clause 6.1.3 d)-f) | **SoA unapproved and residual risks unaccepted.** The Statement of Applicability exists in draft, is complete and traceable, and has not been approved. No single consolidated risk treatment plan exists, and the risk owners have not accepted the residual risk on R-004, R-005 or VR-004. | WP-06 | Chief Executive Officer | Approve SoA v1.0 and one consolidated RTP; obtain signed residual acceptance for the three High residual risks. | 2026-11-30 |
| **NC-04** | Clause 6.2 | **No information security objectives.** Fourteen key risk indicators exist. None carries a target, an owner, a timescale, a resourcing plan or an evaluation method, so none is an objective under 6.2 a) to j). | WP-07 | Chief Technology Officer | Set ISMS objectives built on the 14 KRIs, with targets, owners, dates and an evaluation method. | 2026-11-30 |
| **NC-05** | Clause 7.2 | **No competence requirements or evidence.** No competence requirement is defined for any ISMS role and no documented evidence of competence is retained, as required by 7.2 d). | WP-08 | Head of People and Operations | Publish a role competence matrix; retain training, qualification and experience records. | 2027-03-31 |
| **NC-06** | Clause 9.2.1, 9.2.2 | **No internal audit programme and no internal audit performed.** No audit programme exists (frequency, methods, responsibilities, criteria, scope, reporting) and no internal audit had been conducted before this engagement. This engagement does not close the requirement: the auditor prepared the Statement of Applicability under test. | WP-13 | Chief Executive Officer | Approve an internal audit programme; commission an independent internal audit covering clauses 4-10 and the applicable controls. | 2027-05-31 |
| **NC-07** | Clause 9.3.1, 9.3.2, 9.3.3 | **No management review has ever been held.** Top management has never reviewed the ISMS. No agenda covers the 9.3.2 a) to g) inputs and no documented results or decisions exist. | WP-14 | Chief Executive Officer | Hold management review #1 (Mar 2027) and #2 (Jun 2027) on an agenda covering 9.3.2 a) to g); minute the decisions. | 2027-06-30 |
| **NC-08** | Clause 10.2 | **No nonconformity and corrective action process.** No process or log exists for reacting to nonconformity, evaluating root cause, taking corrective action and reviewing its effectiveness. The exception register (EXC-001 to EXC-003) records approved deviations, which are a different object. | WP-15 | Chief Technology Officer | Publish an NC and corrective action procedure; open the log with the 19 nonconformities in this report. | 2026-12-31 |

| ID | Clause or control | Finding | Workpaper | Owner | Management response | Due |
|---|---|---|---|---|---|---|
| NC-09 | A.5.20, A.5.34; GDPR Art. 28 | **Six of seventeen vendors process data with no DPA.** Six vendors, 35% of the estate, process personal data on the organisation's behalf with no executed data processing agreement (KRI-V1 = 65%). Article 28(3) requires the agreement before processing begins and the processing is already happening, so the finding is independent of the SoA target date. | WP-19 | Chief Technology Officer | Execute the six outstanding DPAs; build the GDPR Article 30 record of processing. | 2026-10-31 |

## Minor nonconformities (10)

| ID | Clause or control | Finding | Workpaper | Owner | Management response | Due |
|---|---|---|---|---|---|---|
| NC-10 | Clause 4.1, 4.2 | **Context and interested parties not documented.** Context survives only as six risk-register assumptions. No interested-parties register exists and the climate-change relevance decision required by Amd 1:2024 has never been made. | WP-01 | Chief Executive Officer | Approve a context, interested-parties and obligations register including the climate-change decision. | 2026-10-31 |
| NC-11 | Clause 4.3 | **ISMS scope drafted but not approved.** The scope statement is complete and names interfaces and dependencies, but has not been approved by top management. This escalates to a major nonconformity if it is still unapproved at Stage 1. | WP-02 | Chief Executive Officer | Approve the ISMS scope and boundary, including the CloudCo shared-responsibility statement. | 2026-10-31 |
| NC-12 | Clause 5.1, 7.1 | **ISMS budget and time allocation unapproved.** The USD 32,100 year-one budget is costed in CGI-RSK-001 and has not been approved, and no staff time is allocated to the ISMS. | WP-03; WP-08 | Chief Executive Officer | Approve the year-one budget and a named time allocation for ISMS work. | 2026-10-31 |
| NC-13 | Clause 5.3 | **No ISMS lead assigned and no RACI.** Document owners exist, but nobody is assigned responsibility for ensuring the ISMS conforms to the standard or for reporting its performance to top management. | WP-03 | Chief Executive Officer | Assign the ISMS lead in writing; publish the ISMS RACI across the SoA controls. | 2026-10-31 |
| NC-14 | Clause 6.1.1, 6.3 | **ISMS risks, opportunities and change planning absent.** Risks and opportunities for the ISMS itself have never been determined, and there is no rule for making changes to the ISMS in a planned manner. | WP-04 | Chief Technology Officer | Record ISMS risks and opportunities; add a change-planning step to the ISMS procedure. | 2026-12-31 |
| NC-15 | Clause 7.3; A.5.4, A.6.3 | **Forty per cent of staff have not acknowledged the policy pack.** CGI-TRK-001 shows 30 of 50 staff acknowledged. Approximately 20 people are bound by rules they have not read, and there is no recurring or role-based awareness programme. | WP-09; WP-16 | Head of People and Operations | Drive acknowledgement to 100%; add a joiner acknowledgement gate; publish the annual curriculum. | 2027-03-31 |

| ID | Clause or control | Finding | Workpaper | Owner | Management response | Due |
|---|---|---|---|---|---|---|
| **NC-16** | Clause 7.5 | **No documented-information control procedure or register.** Individual documents carry control blocks. There is no procedure controlling creation, update, approval, distribution and retention, and no ISMS document register. | WP-10 | Chief Technology Officer | Publish the document and record control procedure and the ISMS document register. | 2026-12-31 |
| **NC-17** | Clause 9.1 | **Monitoring defined but not performed or reported.** One of fourteen indicators has been measured once, as a by-product of the vendor programme. There is no monitoring programme, no analysis or evaluation step and no reporting route. | WP-12 | Chief Technology Officer | Publish a quarterly monitoring report covering all 14 KRIs and the ISMS objectives. | 2027-03-31 |
| **NC-18** | Clause 4.4, 10.1 | **The ISMS does not yet operate as one system.** Policies, register, gap assessment, vendor programme and SoA exist as separate deliverables with no process map linking them and no improvement loop fed by audits, indicators, incidents and exceptions. | WP-02; WP-15 | Chief Technology Officer | Publish an ISMS overview linking the clause 4-10 processes; open the improvement log. | 2026-12-31 |
| **NC-19** | Clause 7.4 | **No ISMS communication plan.** Policies are published and incident communications are defined, but nothing states what ISMS information is communicated, when, to whom, by whom and how. | WP-10 | Chief Technology Officer | Publish the ISMS communication plan. | 2026-12-31 |

## Opportunities for improvement (18)

### OFI-01

| Field | Value |
|---|---|
| ID | **OFI-01** |
| Clause or control | A.5.30, A.8.13 (CG-01) |
| Observation | **Backups have never been restore-tested and no RTO or RPO is declared.** CloudCo snapshots are configured. No restore has been performed, no recovery objectives are declared and the data export path has never been exercised. The SoA target date is 15 Dec 2026 and has not passed, so this is not yet a nonconformity. It becomes one on 16 Dec 2026. |
| Workpaper | WP-21 |
| Owner | IT Operations Manager |
| Recommended action | Approve CGI-POL-006 with RTO and RPO; evidence one restore to a clean environment (this is REC-03 and VRA-2026-001 C4 - run it once). |
| Due | 2026-12-15 |

### OFI-02

| Field | Value |
|---|---|
| ID | **OFI-02** |
| Clause or control | CG-02, ten Annex A controls |

| Field | Value |
|---|---|
| Observation | **The code path behind R-004 is unprotected.** Ten controls tested in WP-22 are Not started: no secure development lifecycle, no coding standard, no mandatory peer review, no branch protection, no scanning, no penetration test, no environment separation, no change record. SoA target dates of 31 Mar 2027 have not passed; this becomes a nonconformity on 01 Apr 2027. |
| Workpaper | WP-22 |
| Owner | Chief Technology Officer |
| Recommended action | Approve CGI-POL-007 and CGI-POL-008; enable branch protection requiring a second reviewer; start authenticated scanning. |
| Due | 2027-03-31 |

### OFI-03

| Field | Value |
|---|---|
| ID | **OFI-03** |
| Clause or control | CG-03, A.8.9, A.8.20-A.8.22 |
| Observation | **No cloud configuration baseline or drift detection.** No baseline, no posture monitoring, no network security baseline and no documented segmentation. This is the documented reason R-005 remains High. |
| Workpaper | WP-23 |
| Owner | IT Operations Manager |
| Recommended action | Implement a CIS AWS Foundations baseline with posture monitoring (Project 7 delivers this). |
| Due | 2027-06-30 |

### OFI-04

| Field | Value |
|---|---|
| ID | **OFI-04** |
| Clause or control | CG-04, A.6.3 |
| Observation | **Awareness is induction-only.** No recurring curriculum, no role-based training, no phishing simulation and no module on the CGI-POL-001 s4.5 AI-use rules that two shadow-IT tools already breach. |
| Workpaper | WP-09 |
| Owner | Head of People and Operations |
| Recommended action | Publish the annual curriculum with a phishing simulation and an AI-use module. |
| Due | 2027-03-31 |

### OFI-05

| Field | Value |
|---|---|
| ID | **OFI-05** |
| Clause or control | CG-05, A.8.10-A.8.12 |
| Observation | **No data loss prevention and no retention execution.** Monitoring is metadata-only. Retention limits are designed in CGI-POL-004 and have never been executed, and no masking exists for logs or lower environments. |
| Workpaper | WP-24 |
| Owner | Chief Technology Officer |
| Recommended action | Implement egress and DLP rules on OfficeCo and CodeCo; execute the retention and deletion schedule. |
| Due | 2027-09-30 |

### OFI-06

| Field | Value |
|---|---|
| ID | **OFI-06** |

| Field | Value |
|---|---|
| Clause or control | Population completeness (IPE) |
| Observation | **The joiner, mover and leaver population cannot be established.** No joiner/leaver register and no archive of completed offboarding checklists exists, so the population for the four-hour revocation control could not be constructed or reconciled to an HR system of record. Five illustrative records in CGI-TRK-001 are not a population. Any future audit or SOC 2 examination will stop at the same point. |
| Workpaper | WP-09; WP-17 |
| Owner | Head of People and Operations |
| Recommended action | Maintain a joiner/mover/leaver register reconciled monthly to the HR system; retain completed offboarding checklists. |
| Due | 2026-12-31 |

### OFI-07

| Field | Value |
|---|---|
| ID | **OFI-07** |
| Clause or control | A.5.23; VRA-2026-001 C1 |
| Observation | **Four CloudCo complementary user entity controls are unaccepted.** Organisation-wide CloudTrail with log file validation, MFA on the root account with restricted root use, least-privilege IAM with periodic review, and encryption management are all assumed by the provider's report and performed by nobody. If C1 is not met by 15 Dec 2026 the conditional pass lapses to Fail. |
| Workpaper | WP-18; WP-23 |
| Owner | Chief Technology Officer |
| Recommended action | Sign the CUEC acceptance record naming four owners; publish the shared-responsibility statement. |
| Due | 2026-12-15 |

### OFI-08

| Field | Value |
|---|---|
| ID | **OFI-08** |
| Clause or control | A.5.35; Clause 9.2.2 c) |
| Observation | **This engagement is not independent.** The auditor prepared CGI-ISO-001, including the Statement of Applicability tested in WP-06. Clause 9.2.2 c) requires auditor selection to ensure objectivity and impartiality. The limitation is declared in the audit plan and the affected workpapers are named. |
| Workpaper | WP-13 |
| Owner | Chief Executive Officer |
| Recommended action | Appoint an auditor independent of the preparer for ISO-12; have the CEO review the WP-06 and WP-13 conclusions in the interim. |
| Due | 2027-03-31 |

### OFI-09

| Field | Value |
|---|---|
| ID | **OFI-09** |
| Clause or control | A.5.22; VRA-2026-002 |
| Observation | **A Tier 1 vendor is operating in FAIL status with no risk acceptance.** ChatCo (CGI-VEN-004) scored 65% and failed on 15 Sep 2026. No CEO-approved, expiring risk acceptance on the ACC-001 pattern is on file. Re-assessment is due 15 Dec 2026. |
| Workpaper | WP-18 |
| Owner | Chief Technology Officer |
| Recommended action | Remediate to a pass, or record a CEO-approved expiring acceptance, before Stage 1. |

| Field | Value |
|---|---|
| Due | 2026-12-15 |

### OFI-10

| Field | Value |
|---|---|
| ID | **OFI-10** |
| Clause or control | SOC 2 CC2.3 |
| Observation | **No system description and no CUECs communicated to customers.** Approximately 200 customers have never been told which controls they must perform for the platform's controls to work. Nothing in ISO-01 to ISO-17 or REC-01 to REC-18 creates this artefact, because ISO 27001 does not require it. |
| Workpaper | WP-24 |
| Owner | Chief Technology Officer |
| Recommended action | Approve the system description and the CUEC schedule (CGI-SOC-001 Part 3); publish the CUECs in the customer agreement and the trust page. |
| Due | 2027-06-30 |

### OFI-11

| Field | Value |
|---|---|
| ID | **OFI-11** |
| Clause or control | SOC 2 CC3.3 |
| Observation | **Fraud has never been considered as a risk category.** CGI-RSK-001 covers phishing, ransomware, insider exfiltration, an authorisation flaw and cloud misconfiguration. It does not consider fraudulent reporting, misappropriation of assets or corruption. ISO/IEC 27001 Annex A has no fraud control, so no ISO action would ever surface this. |
| Workpaper | WP-05 |
| Owner | Chief Executive Officer |
| Recommended action | Add a fraud consideration to the next CGI-RSK-001 review, covering incentives, pressures, opportunities and rationalisations. |
| Due | 2027-03-31 |

### OFI-12

| Field | Value |
|---|---|
| ID | **OFI-12** |
| Clause or control | SOC 2 A1 Availability |
| Observation | **No service commitments are published.** No SLA, uptime target or recovery commitment exists (assumption ISO-A04). The Availability category asks whether the system is available 'as committed'; with no commitment there is nothing to test against. |
| Workpaper | WP-24 |
| Owner | Chief Executive Officer |
| Recommended action | Publish service commitments (uptime target, support response, recovery objectives) before any SOC 2 engagement includes Availability. |
| Due | 2027-06-30 |

### OFI-13

| Field | Value |
|---|---|
| ID | **OFI-13** |
| Clause or control | Clause 8.3 |

| Field | Value |
|---|---|
| Observation | **Treatment actions are dated but unevidenced.** Wave 1 of the treatment plan is not yet due at the audit date, so non-completion is not a nonconformity. No status tracker with evidence per action exists, which will make the position untestable when the dates do pass. |
| Workpaper | WP-11 |
| Owner | Chief Technology Officer |
| Recommended action | Open a treatment status tracker carrying evidence per action. |
| Due | 2026-12-31 |

### OFI-14

| Field | Value |
|---|---|
| ID | **OFI-14** |
| Clause or control | A.5.36, A.5.37 |
| Observation | **No compliance checking and no procedures beneath the policies.** No compliance check against policy has ever run, and the runbooks the policies rely on do not exist. The planned runbook location shares CloudCo with the platform it would be used to recover. |
| Workpaper | WP-16 |
| Owner | Chief Technology Officer |
| Recommended action | Add a quarterly compliance check to the management review agenda; write runbooks and store them outside the platform's own dependency. |
| Due | 2027-06-30 |

### OFI-15

| Field | Value |
|---|---|
| ID | **OFI-15** |
| Clause or control | A.5.18, A.8.2 |
| Observation | **No privileged access review has ever been performed.** CGI-POL-003 s4.7.1 mandates a quarterly privileged access review. Zero have been performed. Four quarterly records are needed before a Stage 2 audit and before any SOC 2 Type II period. |
| Workpaper | WP-17 |
| Owner | IT Operations Manager |
| Recommended action | Perform and retain the first quarterly privileged access review. |
| Due | 2026-12-31 |

### OFI-16

| Field | Value |
|---|---|
| ID | **OFI-16** |
| Clause or control | A.5.24-A.5.27 |
| Observation | **Incident response has never been exercised.** The plan is approved and complete on severity, roles and targets. No containment runbooks exist, no out-of-band channel is named, and no exercise has been held, so there is no evidence of operation at all. |
| Workpaper | WP-20 |
| Owner | Chief Technology Officer |
| Recommended action | Run a SEV1 tabletop; record lessons learned; name an out-of-band channel. |
| Due | 2027-06-30 |

### OFI-17

| Field | Value |
|---|---|
| ID | **OFI-17** |
| Clause or control | A.5.3 |
| Observation | **Segregation of duties on the code path.** Engineers can commit directly to production with no second person. This is the duty conflict behind R-004 and it is also the CC8.1 point of focus an examiner would test first. |
| Workpaper | WP-22 |
| Owner | Chief Technology Officer |
| Recommended action | Publish a segregation-of-duties matrix; require a second reviewer in branch protection. |
| Due | 2027-03-31 |

**OFI-18**

| Field | Value |
|---|---|
| ID | **OFI-18** |
| Clause or control | A.5.9, A.8.1 |
| Observation | **No asset inventory and no endpoint register.** The 17-row vendor inventory is an input to an asset inventory and is frequently mistaken for one. Fifty BYOD endpoints are unregistered and unmanaged, and the four classification tiers have been applied to zero assets. |
| Workpaper | WP-24 |
| Owner | IT Operations Manager |
| Recommended action | Build the asset and SaaS inventory with an owner and a classification per asset; register the 50 endpoints. |
| Due | 2027-03-31 |

## 5.5 Internal audit report

> **To:** Jerry Gold, Chief Executive Officer **From:** O.S, Internal Auditor **Date:** 25 September 2026 **Subject:** Internal audit of the information security management system — CGI-IAU-001

**Audit opinion.** The information security management system of Cypher Group Inc. **does not currently conform to ISO/IEC 27001:2022**. Nine requirements of clauses 4 to 10 are absent rather than incomplete, and the management system elements that a certification body checks first — internal audit, management review, objectives, competence, corrective action and risk acceptance criteria — have never operated. The control layer is materially stronger than the management layer, and the gap between the two is the finding.

**What is genuinely good.** The policy layer is the best-evidenced part of the organisation: five approved topic-specific policies with real document control, approvers corrected for segregation of duties, and a handling matrix with four tiers. The risk process is sound, documented against a recognised method, and has operated twice — clause **8.2 is the only requirement in clauses 4 to 10 that is fully met**, and re-performance of the aggregate arithmetic produced no exception. The vendor programme is designed, owned and communicated, and it found seventeen vendors where the architecture diagram showed five. None of this is common at fifty people and none of it should be understated.

**What is not.** The organisation has built artefacts, not a system. There is no ISMS policy above the five topic policies, no objective anyone is working toward, no measurement anyone reports, no review at which leadership sees any of it, and no log in which a failure would be recorded. Nine major nonconformities follow directly from that, and they are cheap: most are a signature, a meeting or a one-page procedure.

**The single most serious finding is NC-09.** Six of seventeen vendors — 35% of the estate — process personal data with no data processing agreement. That is a present-tense breach of GDPR Article 28, not a roadmap item, and it is the finding most likely to be graded major by a certification body at Stage 2. The deadline is 31 October 2026 and it is a signature, not a project.

**The most instructive finding is OFI-06.** The joiner, mover and leaver population could not be established, because no register and no archive of completed offboarding checklists exists. The four-hour revocation control in CGI-POL-003

section 4.5.2 is therefore **untestable**, and an untestable control is not a passing control. Every future audit and every SOC 2 examination will stop at the same place. Standing up evidence capture (SOC-07) is the highest-value action in this report, because it converts a policy that cannot be audited into one that can.

**Limitation of this engagement.** The auditor prepared the Statement of Applicability tested in WP-06 and is therefore not independent. This report delivers the programme, the method and twenty-four reusable workpapers. It does **not** satisfy clause 9.2, and it does not move the oversight score. The independent audit required by ISO-12 must still take place in May 2027 (**OFI-08**).

**Recommendation.** Close the nine major nonconformities by 30 June 2027 in the order given by the due dates in the register. They are sequenced so that the October 2026 items — scope, ISMS policy, risk acceptance criteria, the six DPAs — unblock the November 2026 items, which unblock the 2027 audit and review cycle. None of the nine requires money. Six of them require a decision from you.

---

## Part 6 — PBC evidence request list

**PBC** means *provided by client* — the list an auditor sends before fieldwork stating exactly what evidence is needed, from whom, in what format, for what period and by when. It is the least glamorous artefact in assurance and the one a junior analyst actually runs.

This list was issued on 25 September 2026 with a return date of 9 October 2026. The status column is the finding: **7 received, 7 partial, 36 not available — 72% of the evidence an examination would need does not exist.**

Three rules govern how it is written. **Name the artefact, not the topic** — "access control evidence" returns a policy, while "MFA enrolment report exported from the identity provider, all accounts, as at 25 Sep 2026" returns something testable. **State the period**, because point-in-time evidence cannot support a test of operation over time. **Ask for system exports, not screenshots**, wherever the system can produce one.

| PBC | Area | Evidence requested | Format | Period | Owner | Status | Feeds |
|---|---|---|---|---|---|---|---|
| **PBC-01** | Governance | Approved ISMS scope statement signed by the CEO | PDF | As at request | Chief Executive Officer | Not available - draft only | WP-02 |
| **PBC-02** | Governance | Top-level information security policy meeting clause 5.2 | PDF | Current version | Chief Executive Officer | Not available - does not exist | WP-03 |
| **PBC-03** | Governance | Context, interested parties and legal obligations register | XLSX | Current version | Chief Executive Officer | Not available - does not exist | WP-01 |
| **PBC-04** | Governance | Approved ISMS budget and allocated time | PDF or email approval | FY2027 | Chief Executive Officer | Not available - unapproved | WP-03; WP-08 |
| **PBC-05** | Governance | Written assignment of the ISMS lead and the ISMS RACI | PDF | Current version | Chief Executive Officer | Not available - does not exist | WP-03 |
| **PBC-06** | Risk | Documented risk assessment method including acceptance criteria | PDF | Current version | Chief Technology Officer | Partial - method held, acceptance criteria missing | WP-05 |
| **PBC-07** | Risk | Risk register with inherent and residual scores and owners | XLSX | v1.0 and v1.1 | Chief Technology Officer | Received - CGI-RSK-001 v1.1, 14 risks | WP-05; WP-11 |
| **PBC-08** | Risk | Signed risk acceptance records | PDF | In force at request | Chief Executive Officer | Received - ACC-001, ACC-V01, AVD-001 | WP-05 |

| PBC | Area | Evidence requested | Format | Period | Owner | Status | Feeds |
|---|---|---|---|---|---|---|---|
| **PBC-09** | Risk | Statement of Applicability, approved | XLSX or PDF | Current version | Chief Executive Officer | Partial - draft held, approval missing | WP-06 |
| **PBC-10** | Risk | Consolidated risk treatment plan with residual acceptance by risk owners | XLSX | Current version | Chief Executive Officer | Not available - not consolidated | WP-06 |
| **PBC-11** | Risk | Information security objectives with targets, owners and dates | XLSX | FY2027 | Chief Technology Officer | Not available - does not exist | WP-07 |
| **PBC-12** | People | Headcount reconciliation: joiners, movers and leavers | XLSX from the HR system | 12 months to the request date | Head of People and Operations | Not available - no register maintained | WP-09; WP-17 |
| **PBC-13** | People | Policy acknowledgement report, per person | XLSX export | Current | Head of People and Operations | Partial - aggregate 60% held; per-person detail for 5 of 50 | WP-09 |
| **PBC-14** | People | Completed offboarding checklists for all leavers in the period | PDF set | 12 months to the request date | Head of People and Operations | Not available - none retained | WP-17 |
| **PBC-15** | People | Competence matrix and training or certification records per ISMS role | XLSX + PDF | Current | Head of People and Operations | Not available - does not exist | WP-08 |
| **PBC-16** | People | Signed confidentiality or non-disclosure agreements | PDF set | All staff and contractors | Head of People and Operations | Not available - none on file | WP-16 |
| **PBC-17** | Access | MFA enrolment report from the identity provider | CSV export | As at request | IT Operations Manager | Partial - aggregate 80% held; no per-account export | WP-17 |
| **PBC-18** | Access | Quarterly privileged access review records | PDF set | 4 most recent quarters | IT Operations Manager | Not available - none performed | WP-17 |
| **PBC-19** | Access | Privileged account list with business justification | XLSX | As at request | IT Operations Manager | Not available - does not exist | WP-17 |
| **PBC-20** | Access | SSO and SCIM coverage list by vendor | XLSX | As at request | IT Operations Manager | Partial - identity provider known; 4 vendors not federated | WP-17; WP-18 |
| **PBC-21** | Vendor | Vendor inventory with tier, owner, DPA status and review date | XLSX | Current | Chief Technology Officer | Received - CGI-TPR-001, 17 vendors | WP-18; WP-19 |
| **PBC-22** | Vendor | Executed data processing agreements | PDF set | All vendors processing personal data | Chief Technology Officer | Partial - 11 of 17 executed | WP-19 |
| **PBC-23** | Vendor | Completed vendor assessments for the period | PDF set | 12 months to the request date | Chief Technology Officer | Received - VRA-2026-001, -002, -003 | WP-18 |
| **PBC-24** | Vendor | Signed CUEC acceptance record for the cloud provider | PDF | Current | Chief Technology Officer | Not available - four CUECs unaccepted | WP-18; WP-23 |
| **PBC-25** | Vendor | Sub-processor change feed subscription and first reconciliation | Screenshot + PDF | Current | Chief Technology Officer | Not available - not subscribed | WP-18 |

| PBC | Area | Evidence requested | Format | Period | Owner | Status | Feeds |
|---|---|---|---|---|---|---|---|
| **PBC-26** | Operations | Change or release record for the platform | CSV export | 12 months to the request date | Chief Technology Officer | Not available - no change record exists | WP-22 |
| **PBC-27** | Operations | Branch protection configuration export | JSON or screenshot | As at request | Chief Technology Officer | Not available - not enabled | WP-22 |
| **PBC-28** | Operations | Vulnerability scan reports and remediation tickets | PDF + CSV | 12 months to the request date | Chief Technology Officer | Not available - no scanning performed | WP-22 |
| **PBC-29** | Operations | Penetration test report | PDF | Most recent | Chief Technology Officer | Not available - never performed | WP-22 |
| **PBC-30** | Operations | Cloud configuration baseline and drift or posture reports | PDF | Current + 12 months | IT Operations Manager | Not available - no baseline exists | WP-23 |
| **PBC-31** | Operations | CloudTrail configuration showing organisation-wide trail and log file validation | Screenshot or CLI output | As at request | IT Operations Manager | Not available - unverified | WP-23 |
| **PBC-32** | Operations | Security alert rules and a sample of handled alerts | Screenshot + ticket export | 12 months to the request date | IT Operations Manager | Not available - no alert rules exist | WP-23 |
| **PBC-33** | Resilience | Backup configuration and schedule | Screenshot | As at request | IT Operations Manager | Received - CloudCo snapshot configuration | WP-21 |
| **PBC-34** | Resilience | Declared RTO and RPO, approved | PDF | Current | IT Operations Manager | Not available - not declared | WP-21 |
| **PBC-35** | Resilience | Restore test reports | PDF | 12 months to the request date | IT Operations Manager | Not available - no restore has been tested | WP-21 |
| **PBC-36** | Incident | Incident register entries with severity and timeline | CSV export | 12 months to the request date | Chief Technology Officer | Not available - no entries; no incidents recorded | WP-20 |
| **PBC-37** | Incident | Tabletop exercise record and lessons learned | PDF | Most recent | Chief Technology Officer | Not available - never exercised | WP-20 |
| **PBC-38** | Data | Asset and SaaS inventory with owner and classification | XLSX | Current | IT Operations Manager | Not available - only the vendor inventory exists | WP-24 |
| **PBC-39** | Data | Endpoint register with encryption and screen-lock compliance | CSV export | As at request | IT Operations Manager | Not available - 50 BYOD endpoints unregistered | WP-24 |
| **PBC-40** | Data | GDPR Article 30 record of processing activities | XLSX | Current | Chief Technology Officer | Not available - does not exist | WP-19 |
| **PBC-41** | Monitoring | KRI measurement results | XLSX | 4 most recent quarters | Chief Technology Officer | Partial - KRI-V1 measured once at 65% | WP-12 |
| **PBC-42** | Monitoring | Internal audit programme and prior audit reports | PDF | Current + prior year | Chief Executive Officer | Not available - none exist | WP-13 |
| **PBC-43** | Monitoring | Management review minutes with 9.3.2 inputs and decisions | PDF | 2 most recent | Chief Executive Officer | Not available - never held | WP-14 |

| PBC | Area | Evidence requested | Format | Period | Owner | Status | Feeds |
|---|---|---|---|---|---|---|---|
| **PBC-44** | Monitoring | Nonconformity and corrective action log | XLSX | 12 months to the request date | Chief Technology Officer | Not available - does not exist | WP-15 |
| **PBC-45** | SOC 2 | Draft system description and management assertion | DOCX | Current | Chief Technology Officer | Not available - drafted in CGI-SOC-001 Part 3, unapproved | WP-24 |
| **PBC-46** | SOC 2 | Published service commitments and system requirements (SLA) | PDF or URL | Current | Chief Executive Officer | Not available - no SLA exists | WP-24 |
| **PBC-47** | SOC 2 | Customer agreement clauses communicating CUECs | PDF | Current template | Head of Customer Success | Not available - no CUECs communicated | WP-24 |
| **PBC-48** | Documentation | Document and record control procedure and the ISMS document register | PDF + XLSX | Current | Chief Technology Officer | Not available - does not exist | WP-10 |
| **PBC-49** | Documentation | Approved topic-specific policies with approval records | PDF set | Current versions | Chief Technology Officer | Received - CGI-POL-001 to -005 v1.0 | WP-16 |
| **PBC-50** | Documentation | Policy exception register | XLSX | Current | Chief Technology Officer | Received - EXC-001 to EXC-003 | WP-15 |

**Reading the status column.** *Not available — does not exist* and *Not available — control not yet operating* are different answers and both are findings. The first says the artefact was never created; the second says the control exists on paper and has produced no records. Thirty-six rows carry one of the two, which is a more direct statement of readiness than any percentage in Part 4.

---

# Part 7 — Roadmap and reconciliation

## 7.1 SOC 2 actions SOC-01 to SOC-14

These are **additional** to ISO-01 to ISO-17 and REC-01 to REC-18, not a replacement for them. Where an ISO action already does the work, the SOC action points at it rather than repeating it.

| ID | Action | Criteria | Owner | Start | Due | Phase | Est. cost (USD) | Dependency |
|---|---|---|---|---|---|---|---|---|
| **SOC-01** | Decide the report strategy and confirm the scope: Security + Availability + Confidentiality, CloudCo carved out, one system (the platform) | All | Chief Executive Officer | 2026-10-01 | 2026-10-31 | Phase 0 - Decide | 0 | ISO-02 |
| **SOC-02** | Approve the system description and the CUEC schedule; publish the CUECs in the customer agreement and on the trust page | CC2.3 | Chief Technology Officer | 2027-01-01 | 2027-06-30 | Phase 1 - Build | 0 | SOC-01 |
| **SOC-03** | Establish an oversight arrangement independent of management: an advisory board seat, or a documented CEO-plus-external-adviser review of the system of internal control | CC1.2 | Chief Executive Officer | 2027-01-01 | 2027-03-31 | Phase 1 - Build | 4,000 | ISO-13 |

| ID | Action | Criteria | Owner | Start | Due | Phase | Est. cost (USD) | Dependency |
|---|---|---|---|---|---|---|---|---|
| SOC-04 | Add a fraud consideration to the risk assessment: fraudulent reporting, misappropriation of assets and corruption, with incentives, pressures, opportunities and rationalisations | CC3.3 | Chief Executive Officer | 2027-01-01 | 2027-03-31 | Phase 1 - Build | 0 | ISO-05 |
| SOC-05 | Publish service commitments and system requirements: uptime target, support response times and recovery objectives | A1.1, A1.2, A1.3 | Chief Executive Officer | 2027-01-01 | 2027-06-30 | Phase 1 - Build | 0 | OFI-01 |
| SOC-06 | Map each control in the SoA to the criteria it serves and maintain the crosswalk as one control set | All | Chief Technology Officer | 2026-11-01 | 2026-12-31 | Phase 1 - Build | 0 | ISO-06 |
| SOC-07 | Stand up evidence capture: ticketing for access reviews, change approvals, incident records, restore tests and vendor reviews, so that a population exists to sample | All | Chief Technology Officer | 2027-01-01 | 2027-03-31 | Phase 1 - Build | 3,000 | REC-06; REC-07 |
| SOC-08 | Select a CPA firm for the examination. It must be independent of whoever performed the readiness work, and different from the ISO certification body | All | Chief Executive Officer | 2027-09-01 | 2027-11-30 | Phase 2 - Engage | 0 | ISO-14 |
| SOC-09 | Readiness re-assessment against the 38 criteria using this workbook | All | Chief Technology Officer | 2027-11-01 | 2027-12-31 | Phase 2 - Engage | 0 | SOC-07 |
| SOC-10 | Type I examination as of 31 March 2028 | All | Chief Executive Officer | 2028-02-01 | 2028-04-30 | Phase 3 - Report | 18,000 | SOC-09 |
| SOC-11 | Type II observation period: 1 April 2028 to 30 September 2028 | All | Chief Technology Officer | 2028-04-01 | 2028-09-30 | Phase 3 - Report | 0 | SOC-10 |
| SOC-12 | Type II examination and report issue | All | Chief Executive Officer | 2028-10-01 | 2028-11-30 | Phase 3 - Report | 25,000 | SOC-11 |
| SOC-13 | Publish a trust page carrying the ISO certificate, the SOC 2 status and the CUEC schedule | CC2.3 | Head of Customer Success | 2027-11-01 | 2027-12-31 | Phase 2 - Engage | 0 | SOC-02 |
| SOC-14 | Bridge statement covering the gap between the Type II period end and a buyer's due diligence date | All | Chief Executive Officer | 2028-12-01 | 2029-01-31 | Phase 4 - Sustain | 0 | SOC-12 |

**SOC 2-specific cost: USD 50,000 (planning estimate).** For context, CGI-ISO-001 estimates USD 22,900 for ISO certification and USD 55,000 for the whole programme to that certificate. SOC 2 roughly doubles the assurance spend, which is why the sequencing in Part 4.4 matters commercially and not just technically.

## 7.2 Conflicts stated explicitly

| ID | Conflict | Why it matters | Resolution |
|---|---|---|---|
| **SC-01** | Two counts of the Statement of Applicability are in circulation: an earlier 0 Implemented / 44 Partial / 44 Not started, and the CGI-ISO-001 v1.2 figure of 0 / 45 / 43 after A.7.7 was corrected from 'Held: none' to Partial. | Every criterion score in Part 2 is derived from the per-control maturities. A one-control difference changes the Annex A base and therefore the crosswalk. | The canonical v1.2 figures are used throughout: 88 applicable, 0 Implemented, 45 Partial, 43 Not started, maturity distribution 43 / 23 / 22. |
| **SC-02** | Two certification-readiness figures are in circulation, 30.4% and 30.6%. CGI-ISO-001 Part 6 and its verification appendix both record 30.6%. | A published readiness figure that differs between two documents is itself an audit finding. | 30.6% is used throughout. The 30.4% reference is corrected at source. |
| **SC-03** | No action anywhere in ISO-01 to ISO-17 or REC-01 to REC-18 produces a system description or a set of complementary user entity controls. | ISO/IEC 27001 requires neither, so no ISO-driven plan would ever create them. Without them there is no SOC 2 engagement at all (gate SG-3, and the report has no Section 3). | New action SOC-02. Mirrors RC-03 in CGI-ISO-001, where the internal audit was missing for the same structural reason. |
| **SC-04** | CC1.2 requires a governing body independent of management that exercises oversight of the system of internal control. ISO-13 creates management reviews chaired by the CEO, who is management. | Gate SG-2 fails and cannot be closed by any ISO action. A 50-person founder-led company has no board. | New action SOC-03: an advisory board seat or a documented CEO-plus-external-adviser review. State the arrangement in the system description rather than claiming a board that does not exist. |
| **SC-05** | CC3.3 requires the potential for fraud to be considered in assessing risks. ISO/IEC 27001:2022 Annex A contains no fraud control and CGI-RSK-001 v1.1 contains no fraud risk. | A criterion with no ISO counterpart will never be surfaced by an ISO-driven roadmap. | New action SOC-04. Recorded as OFI-11 in the internal audit so it enters the ISO improvement loop as well. |
| **SC-06** | The Availability category asks whether the system is available 'as committed'. Assumption ISO-A04 records that no contractual SLA figure exists anywhere in Projects 1-4. REC-14 delivers a status page, not a commitment. | Availability cannot be examined against a commitment that has never been made. | New action SOC-05: publish service commitments before any engagement includes A1. Until then, A1 is in scope for readiness planning only. |
| **SC-07** | ISO-12 budgets USD 6,000 for an independent internal audit in May 2027. The SOC 2 readiness work covers much of the same evidence. | Paying twice for one walk through the same controls is waste, and two uncoordinated engagements produce two different views of the same facts. | Combine them: one engagement in May 2027 delivering the ISO clause 9.2 internal audit and the SOC 2 readiness re-assessment. The independent auditor uses this workbook. No change to the ISO-12 budget. |
| **SC-08** | ISO-14 selects an accredited certification body. SOC 2 needs a CPA firm, and under the AICPA Code of Professional Conduct the firm that designs or implements controls cannot examine them. | Appointing the readiness adviser as the examiner would void the report. | New action SOC-08, with an explicit instruction that the readiness provider and the examining CPA firm must be different organisations. |

**The pattern behind SC-03, SC-04 and SC-05 is the same one CGI-ISO-001 found with RC-03.** A roadmap built from one framework is blind to the requirements of another, and the blindness is structural rather than careless: no amount of care applied to ISO/IEC 27001 will produce a system description, a set of CUECs, an independent oversight body or a fraud consideration, because ISO does not ask for any of them. **Crosswalking is how you find out what your plan cannot see.**

## 7.3 What does *not* change

Nothing in ISO-01 to ISO-17 moves, and nothing in REC-01 to REC-18 moves. The ISO dates in CGI-ISO-001 — Stage 1 July 2027, Stage 2 October 2027, certificate November 2027 — stand, and REC-06 remains the one date that cannot

slip. **SOC-07 (evidence capture) is scheduled in Q1 2027 precisely so that it rides alongside REC-06 and REC-07 rather than competing with them**, and SC-07 removes a duplicate engagement rather than adding one.

---

## Part 8 — One-page executive summary

> **To:** Jerry Gold, Chief Executive Officer · **From:** O.S, Assessor and Internal Auditor **Date:** 25 September 2026 **Subject:** Can we sell against a SOC 2, and did our controls actually run?

**Answer: not yet, and no. A SOC 2 Type II report is realistic for November 2028, after the ISO certificate in November 2027. Nothing we have built has operated yet.**

**Where we stand.**

- Once Security, Availability and Confidentiality are chosen, **38 criteria apply**. **8 have an adequate design. None has operating evidence.**
- **Type I readiness 53.9%. Type II readiness 36.0%. 6 of 8 gates fail**, so both are a no-go regardless of the percentages.
- Our own internal audit raised **37 findings — 9 major, 10 minor, 18 for improvement**.
- Of fifty pieces of evidence an examiner would ask for, **36 do not exist**.

**The four things that matter.**

1. **We have artefacts, not a system.** Nine major nonconformities are all the same shape: no ISMS policy, no objectives, no risk acceptance criteria, no competence records, no internal audit, no management review, no corrective action log, no approved SoA. **Not one of them costs money. Six of them need a decision from you, in October.**
2. **We ask our customers to do what we have not done ourselves.** We must publish ten complementary user entity controls telling ~200 customers to enable MFA, review their own access, read their own logs and classify their own data. CloudCo wrote us four equivalent controls and **we have accepted none of them**. Four for four. Fix ours before we publish theirs — the deadline is already 15 December 2026.
3. **Our leaver control cannot be tested.** Not failed — **untested**, because no leaver register exists to build a population from. Every audit and every examination will stop at the same point. Standing up evidence capture in Q1 2027 is the highest-value item in this report.
4. **Six vendors still have no data processing agreement.** It was the most likely serious audit finding in September and it still is. It is a signature, and the deadline is 31 October 2026.

**What I need from you.** In October 2026: approve the scope, the ISMS policy, the risk acceptance criteria and the budget, and sign the CloudCo CUEC acceptance. In Q1 2027: fund evidence capture (about USD 3,000) and establish an oversight arrangement independent of management, because **no ISO action will ever create one and criterion CC1.2 cannot be met without it.**

**Cost.** About **USD 50,000** for SOC 2 on top of the USD 55,000 already planned for ISO.

**What it buys.** ISO answers the European buyer. SOC 2 answers the US and enterprise buyer, who will not accept the ISO certificate in its place. Until then, the honest sales answer is a published roadmap with dates and this assessment attached — not "we are working on it".

**What this report does not do.** It does not satisfy clause 9.2. I prepared the Statement of Applicability that I tested, so this is a dress rehearsal, not the performance. The independent audit still has to happen in May 2027.

---

# Part 9 — Effect on the CGI-GAP-001 maturity score

## 9.1 The score does not move

**The overall CGI-GAP-001 score stays at 1.32 / 4.00 (29 ÷ 22). No Category moves.**

The same restraint that governed Projects 4 and 5 governs this one. A crosswalk maps controls onto a second framework; it implements none of them. A dry-run audit tests controls; it implements none of them either. **A prerequisite is not a score, and an approved but unevidenced control is a 2.**

## 9.2 Does a completed internal audit move GV.OV? Not this one — and here is the catch

GV.OV is Oversight: *does leadership actually check whether the security strategy is working?* A completed, independent internal audit **is** operating evidence for it. That premise is correct, and it is exactly why the answer here is still no.

**GV.OV stays at 1**, for two reasons, and the second is the one that matters.

**First, the audit was not reported anywhere.** Clause 9.2.2 f) requires audit results to be reported to relevant management. There is no management review to report into (**NC-07**) and no corrective action log for the findings to enter (**NC-08**). An audit whose results stop at the auditor's desk is not oversight; it is paperwork.

**Second, the audit was not independent.** The auditor prepared CGI-ISO-001, including the Statement of Applicability tested in WP-06. Clause 9.2.2 c) requires objectivity and impartiality, and A.5.35 asks for an *independent* review. So:

> **The project that proves a control cannot be the control.**

A.5.35 therefore stays at maturity 0 and Not started, unchanged from CGI-ISO-001.

## 9.3 What would move it, and when

| Point in time | Sum / Categories | Overall | Categories that move | Why |
|---|---|---|---|---|
| Today, on delivery of CGI-SOC-001 and CGI-IAU-001 | 29 / 22 | **1.32** | No Category moves. | A crosswalk maps controls and a dry-run audit tests them. Neither implements anything. The same restraint that held for Project 5 holds here: a prerequisite is not a score. |
| After ISO-01 and ISO-02 are approved (Oct 2026) | 30 / 22 | **1.36** | GV.OC 1 -> 2 | Context, interested parties, obligations and the approved scope are the documented outputs GV.OC asks for. |
| After the independent ISO-12 audit and management review #2 (Jun 2027) | 32 / 22 | **1.45** | GV.OV 1 -> 3, with GV.OC already at 2 | A completed, independent internal audit whose results are reported to top management and whose findings enter a corrective action log IS operating evidence of oversight. A.5.35 moves from Not started to Implemented at the same moment. |

The move to **3** at the third row is deliberate and is consistent with the GV.SC precedent rather than in tension with it. GV.SC stayed at 2 after Project 4 because the supplier review cycle had been **designed and had never fired**. GV.OV reaches 3 in June 2027 because by then the oversight cycle will have **fired once, end to end**: an independent audit performed, results reported to top management at review #2, decisions minuted, findings entered in a corrective action log. One complete occurrence is operating evidence. Zero occurrences is not.

At that point **A.5.35 moves from Not started to Implemented** — and it would be the first control in the entire Statement of Applicability to get there.

---

# Appendix A — Verification, assumptions and limitations

## A.1 Verification performed in code, not by eye

| Check | Result |
|---|---|
| 38 criteria: Security 33 + Availability 3 + Confidentiality 2 | Pass |
| Every criterion maps to at least one Annex A control or clause requirement | Pass — 0 unmapped |
| Annex A source: 93 controls, 88 applicable, 5 excluded | Pass |
| Annex A statuses reconcile to CGI-ISO-001 v1.2: 0 Implemented, 45 Partial, 43 Not started | Pass |
| Annex A maturity distribution reconciles: 43 at 0, 23 at 1, 22 at 2 | Pass |
| Clause source: 28 requirements, total score 19, one requirement fully met (8.2) | Pass |
| ISO Stage 1 gates failing: 8 of 8 (4.3, 6.1.2, 6.1.3, 9.2.1, 9.2.2, 9.3.1, 9.3.2, 9.3.3) | Pass — unchanged from CGI-ISO-001 |
| Type I readiness = 41 ÷ 76 = 53.9% | Recomputed in code and as workbook formulas |
| Type II readiness = 41 ÷ 114 = 36.0% | Recomputed in code and as workbook formulas |
| Criteria with adequate design = 8; with operating evidence = 0 | Pass |
| SOC 2 gate failures = 6 of 8 | Pass |
| No criterion can exceed CRL 2 while zero Annex A controls are Implemented | Pass — 0 criteria at CRL 3 |
| Framework overlap: 77 of 88 applicable controls mapped, 11 unmapped, 7 clause requirements unmapped | Pass |
| Workpapers: 24; every one carries a population, a sample method and separate design and operating results | Pass |
| Findings: 37 = 9 major + 10 minor + 18 OFI; every finding carries an owner, a response and a date | Pass — 0 blanks |
| No finding claims operating evidence that CGI-ISO-001 records as absent | Pass — manually reconciled control by control |
| PBC list: 50 requests; 7 received, 7 partial, 36 not available | Pass |
| Every vendor reference (CGI-VEN-001 to -017), finding (F-001 to F-013, O-001), condition (C1–C4) and KRI cited exists in CGI-TPR-001 | Pass |
| Every risk ID cited (R-001 to R-005, VR-001 to VR-009) exists in CGI-RSK-001 v1.1 | Pass |
| Every control gap cited uses the canonical IDs: CG-01 backup · CG-02 secure dev and vuln mgmt · CG-03 cloud config · CG-04 awareness · CG-05 DLP · CG-06 closed | Pass |
| Every owner is a job title; the simulated cast matches CGI-ISO-001 | Pass |
| CGI-GAP-001 unchanged at 29 ÷ 22 = 1.32; no Category moves | Pass |
| WP-06 sample reproducible from seed 20260925 | Pass — published in `data/06-wp06-soa-sample.csv` |
| Workbook recalculated in LibreOffice; every issue-checklist row PASS | Pass — 17 sheets, 814 formulas, 0 errors, 30 of 30 checks PASS |

## A.2 Assumptions

| ID | Assumption | Why it matters |
|---|---|---|
| SOC-A01 | The AICPA 2017 Trust Services Criteria comprise 33 common criteria (CC1–CC9), 3 Availability, 2 Confidentiality, 5 Processing Integrity and 8 Privacy criteria, with the 2022 revised points of focus. Wording here is paraphrased | The crosswalk is built on the criterion set. Purchase the criteria from the AICPA before using this in anger |

| ID | Assumption | Why it matters |
|---|---|---|
| SOC-A02 | CloudCo is the only subservice organisation. ChatCo, PaymentsCo, OfficeCo and the remaining vendors are vendors, not subservice organisations | Decides the carve-out. The examining CPA firm will test this judgement, and it should be revisited if ChatCo enters the customer-facing support path |
| SOC-A03 | Cypher Group Inc. is a **processor** for its customers' personal data and a **controller** for its own employee data | Decides why Privacy (P1–P8) is out of scope for the first report |
| SOC-A04 | Sample-size rules of thumb are industry practice informed by AICPA guidance, not a published mandatory table | Any examiner may apply different sizes. The rule that matters is that the basis is stated and reproducible |
| SOC-A05 | SOC 2 costs are planning estimates for a fifty-person single-system scope, not quotes | Obtain three CPA firm quotes at SOC-08 |
| SOC-A06 | The audit period is the ISMS's entire existence, 7 to 25 September 2026, because nothing predates it | It is why so many populations are zero, and why this is a dry run rather than a period audit |
| SOC-A07 | CGI-ISO-001 v1.2 counts (0 / 45 / 43) supersede the earlier 44 / 44 count still in circulation | Recorded as conflict SC-01 |

### A.3 Limitations

- **This is a documentation and design review.** No control was technically tested, no system was accessed and no configuration was inspected directly. Every result rests on the artefacts produced by Projects 1 to 5.
- **The auditor is not independent.** Declared at the top of this document and recorded as OFI-08. WP-06 and WP-13 are the affected workpapers.
- **Criterion readiness levels are derived, not observed.** They inherit the assessor judgement in the CGI-ISO-001 maturity scores. A second assessor could differ by one level on individual controls; the banding rule and the design-hole rule bound how far that can travel.
- **No opinion is expressed on the SOC 2 criteria.** A readiness assessment is advice. Only an independent CPA firm can examine and opine, and this document is explicit that it is not one.
- **AICPA and ISO wording is paraphrased**, and both are copyrighted. Buy them.

---

## Appendix B — Glossary

| Term | Definition |
|---|---|
| **AICPA** | American Institute of Certified Public Accountants — owns the SOC framework and the Trust Services Criteria |
| **Attestation** | An engagement in which management asserts and a practitioner attests to the assertion. Contrast certification, where a body audits and issues a certificate |
| **AT-C 105 / 205** | The AICPA attestation sections governing an examination engagement |
| **C&A** | Completeness and accuracy — proving that a population is whole and correct before sampling it |
| **Carve-out method** | A subservice organisation's controls are excluded from the description and from testing; the organisation is named and CSOCs are listed. Contrast the inclusive method |
| **CC1–CC9** | The Common Criteria — the Security category, mandatory in every SOC 2 |
| **CG-01 to CG-06** | CGI-RSK-001 control gaps: backup · secure development and vulnerability management · cloud configuration · awareness · data loss prevention · third-party assurance (closed) |
| **COSO** | Committee of Sponsoring Organizations of the Treadway Commission; its 2013 internal control framework and 17 principles sit inside CC1–CC5 |
| **CPA firm** | A firm of licensed Certified Public Accountants; the only body that may issue a SOC 2 report |
| **CRL** | Criterion Readiness Level — this document's 0–3 measure, defined in Part 2.2 |
| **CSOC** | Complementary subservice organization control — a control a supplier must perform for the provider's controls to work |
| **CUEC** | Complementary user entity control — a control the customer must perform for the provider's controls to work |

| Term | Definition |
|---|---|
| **Exception** | A single instance in which a control did not operate as described. Does not automatically qualify the opinion |
| **Gate** | A requirement whose absence makes the engagement impossible regardless of the score |
| **IPE** | Information produced by the entity — any report the client generates for the auditor, which must itself be proven reliable |
| **Major / minor nonconformity** | Requirement absent or systemically broken / an isolated lapse against a requirement that otherwise works |
| **OFI** | Opportunity for improvement — auditor advice; not a nonconformity |
| **Opinion** | Unqualified (clean) · Qualified ("except for") · Adverse · Disclaimer |
| **PBC** | Provided by client — the evidence request list issued before fieldwork |
| **Point of focus** | A suggested characteristic illustrating a criterion. **Not a requirement** |
| **Population** | Every occurrence of a control in the period. A population of zero cannot be sampled |
| **SOC 1 / SOC 2 / SOC 3** | Financial reporting controls / Trust Services Criteria / a public summary of a SOC 2 |
| **SSAE 18** | Statement on Standards for Attestation Engagements No. 18, under which a SOC 2 is performed |
| **Subservice organisation** | A vendor whose controls form part of the service being described. For Cypher Group Inc.: CloudCo |
| **System description** | Management's own written account of the system — Section 3 of a SOC 2 report |
| **ToD / ToE** | Test of design / test of operating effectiveness |
| **TSC** | Trust Services Criteria. The five **categories** are Security, Availability, Confidentiality, Processing Integrity and Privacy; **CC6** is a criteria group; **CC6.2** is a criterion |
| **Type I / Type II** | Design and implementation as of a date / design and operating effectiveness over a period |
| **User entity** | A customer of the service organisation |
| **Workpaper** | The auditor's record of one test, and the evidence that the audit itself was performed properly |

## Source documents

| ID | Document | Version | Status |
|---|---|---|---|
| CGI-POL-001 to -005 | Startup Security Policy Pack | 1.0 | Approved |
| CGI-TRK-001 | Policy acknowledgement and MFA tracker | 1.0 | 60% acknowledged, 80% MFA |
| CGI-RSK-001 | Master Information Security Risk Register | 1.1 | 14 risks after the CGI-TPR-001 merge |
| CGI-GAP-001 | NIST CSF 2.0 Gap Assessment and Maturity Scorecard | 1.0 | 1.32 / 4.00 after Project 4 |
| CGI-TPR-001 / -002 | Vendor Risk Programme / Questionnaire | 1.0 | 17 vendors; VRA-2026-001 to -003 |
| CGI-ISO-001 | ISO/IEC 27001:2022 Readiness Assessment and SoA | 1.0 (v1.2 package) | Draft for approval |
| **CGI-SOC-001 / CGI-IAU-001** | **This document** | **1.0** | **Draft for approval** |
| AICPA TSC 2017 (2022 points of focus) | Trust Services Criteria | 2017/2022 | Referenced, paraphrased |
| ISO/IEC 27001:2022 + Amd 1:2024 | Information security management systems — Requirements | 2022 | Referenced, paraphrased |
| SSAE 18 / AT-C 105, 205 | Attestation standards | — | Referenced |

*End of CGI-SOC-001 and CGI-IAU-001 v1.0. Prepared by O.S. For approval by Jerry Gold.*